SUP'COM

RECUEIL DES BESOINS

Projet ExamGuard

Besoins fonctionnels et ingénierie des exigences de sécurité
(IES / *Security Requirements Engineering*)

Encadrant : Mohamed-Bécha Kaâniche

Équipe projet :

— Laith GRITLI
— Ahmed ABDELHEDI
— Mohamed Yassine AMRI

Pile technique : PWA React, Jakarta EE 11, WildFly 42, Java 25, PostgreSQL 18.

Version : 2.0 – 12 novembre 2026

Année universitaire 2026–2027

Table des matières

1 Introduction **1**
- 1.1 Fiche du document . . . 1
- 1.2 Objet du document . . . 1
- 1.3 Références . . . 2
- 1.4 Glossaire et conventions . . . 2

2 Démarche d'ingénierie des exigences de sécurité **3**
- 2.1 Processus suivi . . . 3
- 2.2 Comparaison des approches . . . 3
- 2.3 Approche retenue et justification . . . 3
- 2.4 Application à ExamGuard . . . 4

3 Contexte de sécurité du système **6**
- 3.1 Acteurs et niveaux de confiance . . . 6
- 3.2 Actifs et objectifs de sécurité . . . 6
- 3.3 Directives de sécurité . . . 7
- 3.4 Décisions techniques figées . . . 7

4 Besoins fonctionnels **9**
- 4.1 Cas d'utilisation . . . 9
- 4.2 Exigences fonctionnelles . . . 9
- 4.3 Matrice des droits . . . 10

5 Mécanismes de dissimulation **11**
- 5.1 Trois couches complémentaires . . . 11
- 5.2 Clés et principe de Kerckhoffs . . . 12
- 5.3 Rapport d'investigation . . . 12

6 Cas d'abus et cas d'utilisation de sécurité **14**
- 6.1 Méthode et acteurs malveillants . . . 14
- 6.2 Diagrammes . . . 14
- 6.3 Fiches des cas d'abus . . . 15
- 6.4 Cas d'utilisation de sécurité . . . 19
- 6.5 Récits d'abus et récits de sécurité . . . 20

7 Modélisation des menaces **22**
- 7.1 Revue de l'application : déploiement . . . 22
- 7.2 Arbre d'attaque . . . 22
- 7.3 Identification et cotation des menaces . . . 23

8 Exigences de sécurité **25**

9 Validation et traçabilité **34**
- 9.1 Stratégie de test . . . 34
- 9.2 Du cas d'abus au test . . . 34

10 Gestion des exigences **35**
- 10.1 Processus de changement et suivi . . . 35
- 10.2 Planification par itération . . . 35
- 10.3 Évolution depuis la version 1.0 . . . 36

11 Limites et risques résiduels **37**
- Conclusion . . . 37

1. Introduction

1.1 Fiche du document

Projet	ExamGuard : distribution de sujets d'examen dont chaque exemplaire est individualisé et traçable.
Approche IES / SRE	Cas d'abus puis cas d'utilisation de sécurité ; récits d'abus et de sécurité ; STRIDE, OWASP Risk Rating et arbres d'attaque (chapitre 2).
Contenu	21 exigences fonctionnelles ; 12 cas d'abus ; 11 cas d'utilisation de sécurité ; 18 menaces cotées ; 57 exigences de sécurité chiffrées, associées à des tests prévus, priorisées et tracées.
Documents liés	Cahier des charges (`docs/cahier_des_charges.pdf`) ; annexes de sécurité (`docs/annexes_securite.pdf`) : algorithmes de marquage détaillés, décomposition du modèle de menaces, plan de tests, fiches détaillées.

Version	Date	Nature de la modification	Statut
1.0	06/11/2026	Première rédaction (F-01 à F-19, S-01 à S-26).	Remplacée
2.0	12/11/2026	Refonte collective du trinôme : SRE au sens de sécurité, cas d'abus, OWASP Risk Rating, risques métier, 57 exigences testables, fingerprinting multipages, précautions anti-collusion, preuve d'intégrité détachée et protocole d'essais.	Soumise à validation

1.2 Objet du document

Ce document recense les besoins d'ExamGuard, plateforme de distribution de sujets d'examen dont le cœur métier repose sur la stéganographie, le *watermarking* et le *fingerprinting*. Il complète le cahier des charges. Les exigences de sécurité y sont énumérées séparément des exigences fonctionnelles, afin d'être examinées et testées séparément :

— les **exigences fonctionnelles** (chapitre 4) disent ce que le système doit faire ;

— les **exigences de sécurité** (chapitre 8), issues de la démarche des chapitres 2 à 7, disent ce qu'il ne doit pas permettre.

Dans tout le document, **SRE** désigne *Security Requirements Engineering*, l'ingénierie des exigences de sécurité (IES). La version 1.0 avait lu ce sigle comme *Site Reliability Engineering* ; ce contresens est corrigé. Les objectifs de disponibilité et de reprise de l'ancien chapitre sont conservés comme exigences de la famille ES-DSP.

1.3 Références

[R1]	Cours *Sécurité applicative*, M.-B. Kaâniche, SUP'COM, chapitres 1 et 2.
[R2]	OWASP *Application Security Verification Standard* (ASVS) 5.0.0, mai 2025.
[R3]	NIST SP 800-63B-4 (authentifiants), NIST SP 800-38D (GCM), FIPS 180-4 (SHA-256).
[R4]	RFC 9106 (Argon2), 8446 (TLS 1.3), 8032 (Ed25519), 5869 (HKDF), 6238 (TOTP), 8439 (ChaCha20), 9457 (erreurs HTTP).
[R5]	Loi organique n° 2004-63 du 27 juillet 2004 sur la protection des données à caractère personnel (Tunisie).
[R6]	Brassil *et al.*, *Electronic Marking and Identification Techniques to Discourage Document Copying*, IEEE JSAC, 1995.
[R7]	Chen et Wornell, *Quantization Index Modulation*, IEEE Trans. Inf. Theory, 2001 ; Westfeld et Pfitzmann, *Attacks on Steganographic Systems*, 1999.
[R8]	OWASP *Risk Rating Methodology*, `https://owasp.org/www-community/OWASP_Risk_Rating_Methodology` ; grille des facteurs de vraisemblance et des impacts technique/métier (consultée le 12/11/2026).
[R9]	WildFly 42, notes de version, 22/10/2026 : Java 25 recommandé mais conformité EE 11 explicitement attestée avec Java 17 et 21 ; `https://www.wildfly.org/news/2026/10/22/WildFly-42-is-released/`.

1.4 Glossaire et conventions

Statut des valeurs chiffrées. Les paramètres, seuils de qualité et scores de risques du présent document sont des *spécifications initiales* retenues pour la conception. Tant qu'un test d'acceptation n'a pas été exécuté et archivé, ils ne constituent pas des résultats mesurés ni des garanties de sécurité démontrées. Tout écart expérimenté entraîne une demande de changement tracée, jamais une affirmation non prouvée.

Terme	Définition retenue
Sujet original	Fichier PDF déposé par l'enseignant, avant tout marquage.
Exemplaire	Copie du sujet individualisée pour un destinataire.
Distribution	Association d'un exemplaire à un destinataire pour une session d'examen.
Filigrane (*watermark*)	Marque robuste identifiant l'examen, identique sur tous ses exemplaires.
Empreinte (*fingerprint*)	Marque propre à un exemplaire, qui permet de retrouver sa distribution.
Manifeste	Enregistrement signé d'une distribution, dissimulé par stéganographie dans l'exemplaire.
Cas d'abus, cas d'utilisation de sécurité	Cas d'utilisation inversé décrivant un acteur malveillant (« threatens ») ; cas d'utilisation décrivant la parade du système (« mitigates »).

Repères : NC (niveaux de confiance), A (actifs), OS (objectifs), DS (directives), DT (décisions), UC (cas d'utilisation), F (fonctionnel), AC (abus), SUC (cas de sécurité), M (menaces), ES (exigences de sécurité), TS/TA/TF (tests). **Priorités :** P1 indispensable, P2 importante, P3 souhaitable. **Itérations :** It.1–It.5, alignées sur les chapitres 3–7 du cours.

2. Démarche d'ingénierie des exigences de sécurité

2.1 Processus suivi

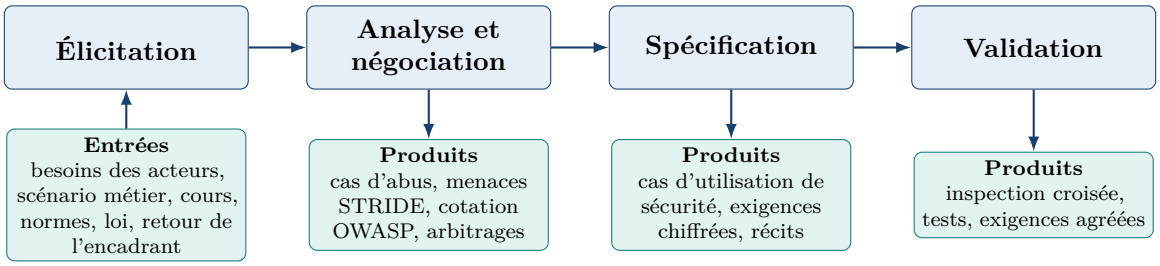


FIGURE 2.1 – Activités de l'ingénierie des exigences de sécurité appliquées à ExamGuard ; la gestion des exigences (chapitre 10) les prolonge tout au long du projet

2.2 Comparaison des approches

Le cours distingue les approches *dérivées* (cas d'abus, cas d'utilisation de sécurité, récits) et *dédiées* (SQUARE, OCTAVE). Le tableau reprend ceux de ses critères qui pèsent le plus pour un trinôme.

Critère	Cas d'abus / CU de sécurité	Récits	SQUARE	OCTAVE
Support de l'élicitation	Élevé	Modéré – élevé	Faible – modéré	Modéré – élevé
Résolution des ambiguïtés à l'analyse	Faible	Faible	Élevé	Aucun
Niveau de traçabilité	Faible	Élevé	Faible	Modéré
Rigueur de la spécification	Informelle	Informelle	Semi-formelle	Formelle
Facilité de modification des exigences	Facile	Facile	Modérée	Difficile
Intelligibilité pour une équipe novice	Facile	Facile	Modérée	Difficile

TABLE 2.1 – Comparaison des approches IES/SRE (critères et appréciations issus de [R1])

2.3 Approche retenue et justification

Approche principale : cas d'abus puis cas d'utilisation de sécurité. Chaque cas d'utilisation est confronté à des cas d'abus (« threatens ») ; chaque cas d'abus est contrecarré par un cas d'utilisation de sécurité (« mitigates ») dont sont dérivées les exigences. Trois arguments :

1. elle offre le meilleur support d'élicitation et impose le point de vue de l'attaquant, objectif fixé par l'encadrant ;

2. elle part du métier : les abus propres à la dissimulation (effacement d'une empreinte, collusion, incrimination d'un innocent) apparaissent d'eux-mêmes, ce qu'une liste de contrôle générique ne produit pas ;
3. elle est facile à apprendre et à modifier, ce qui convient à un recueil qui suit l'agenda du cours.

Compléments, choisis pour compenser ses faiblesses. *Récits d'abus et de sécurité* : leur traçabilité élevée compense celle, faible, des cas d'utilisation ; chaque récit devient une *issue* GitHub. *Catégorisation, priorisation et inspection* empruntées à SQUARE (étapes 7 à 9), parce que les cas d'utilisation résolvent mal les ambiguïtés. *STRIDE* catégorise les menaces, *OWASP Risk Rating* évalue leur vraisemblance et leur impact métier, et les arbres d'attaque examinent les chemins exploitables. DREAD est écarté pour sa subjectivité et sa faible reproductibilité : il repose sur des appréciations ambiguës (notamment « découvrabilité ») et ne reflète pas assez explicitement les conséquences institutionnelles d'une fuite ou d'une accusation erronée.

Approches non retenues comme cadre principal. SQUARE reste applicable à de petits projets en version adaptée : ses neuf activités sont pertinentes. Nous reprenons ses étapes de classement, priorisation et inspection, tout en pilotant les travaux par les cas d'abus et leurs contre-cas pour garder les décisions traçables et liées à chaque flux métier. OCTAVE : évaluation des risques à l'échelle d'une organisation, difficile pour une équipe novice et à modifier. UMLsec et SecureUML : supposent une chaîne d'ingénierie dirigée par les modèles. SERA : analyse par chaînes de mission, disproportionnée ici.

2.4 Application à ExamGuard

Élicitation. *Brainstorming* du trinôme à partir du scénario métier ; dérivation des cas d'abus selon les huit étapes du cours ; ASVS 5.0 comme liste de contrôle ; retour écrit de l'encadrant.

Analyse et négociation. Les besoins ne sont pas spécifiés directement : ils sont modélisés (cas d'abus, menaces, risques), puis les conflits sont arbitrés.

N°	Conflit	Arbitrage
CN-1	Robustesse, imperceptibilité et capacité du marquage sont antagonistes.	Décalage limité à 0,40 pt, charge de 64 bits répétée 3 fois ; la résistance à la numérisation est un objectif étendu.
CN-2	Une PWA incite à mettre en cache ; les sujets sont confidentiels.	Seule l'enveloppe applicative est mise en cache (ES-CFG-01).
CN-3	Marquage robuste par rastérisation contre texte sélectionnable.	Marquage par espacement inter-mots ; deux autres couches compensent.
CN-4	Hachage coûteux contre risque de déni de service.	Paramètres de la RFC 9106 et simultanéité bornée (ES-DSP-02).
CN-5	Attribuer une fuite sans jamais accuser à tort.	Abstention si une marque est invalide ; rapport gradué (ES-DIS-03, ES-DIS-09).

Spécification et validation. Chaque exigence respecte les cinq critères du cours : *spécifique* (mécanisme, algorithme et paramètres nommés), *mesurable* (critère de vérification à résultat binaire), *exploitable* (ancrée dans la pile technique), *réaliste* (les objectifs

incertains sont hors engagement), *opportune* (priorité issue de la cotation du risque, et itération). Les exigences se répartissent dans les deux classes du cours : exigences de sécurité fonctionnelles (ES) et directives (DS). Chacune est inspectée par un membre qui n'en est pas l'auteur ; la version agréée est celle que valide l'encadrant.

3. Contexte de sécurité du système

3.1 Acteurs et niveaux de confiance

Les comptes techniques figurent au même titre que les rôles métier, car ils sont des cibles d'élévation de privilèges.

ID	Niveau de confiance	Droits
NC-0	Internaute anonyme	Enveloppe de la PWA et page de connexion. NC-1 désigne le même internaute après un échec d'authentification.
NC-2	Responsable d'examen	Télécharge son propre exemplaire.
NC-3	Enseignant	Crée ses sessions, dépose ses sujets, distribue.
NC-4	Auditeur (second facteur)	Investigation ; distributions et journal en lecture seule.
NC-5	Administrateur (second facteur)	Comptes et rôles ; ni sujets ni investigation.
NC-6	Processus WildFly	Compte système `wildfly` ; seul lecteur des clés et du stockage.
NC-7	Compte BD applicatif	Rôle `examguard_app` ; insertion et lecture seulement sur le journal. NC-8 : rôle `examguard_ro`, lecture seule.
NC-9	Administrateur de la base	Accès complet au SGBD ; ses actions doivent rester détectables. NC-10 : administrateur du système.

3.2 Actifs et objectifs de sécurité

ID	Actif	Description	C	I	D
A-1	Sujets originaux	PDF des sujets avant l'épreuve. Actif principal.	3	3	2
A-2	Exemplaires individualisés	Copies marquées, une par destinataire.	3	3	2
A-3	Table des distributions	Correspondance empreinte, exemplaire, destinataire.	3	3	2
A-4	Clés cryptographiques	Clés de chiffrement, de marquage et de signature.	3	3	3
A-5	Authentifiants et sessions	Empreintes des mots de passe, secrets TOTP, sessions.	3	3	1
A-6	Journal d'audit	Traces et reçus de téléchargement.	2	3	2
A-7	Données personnelles	Nom, prénom, adresse institutionnelle, rôle.	2	2	1
A-8	Disponibilité du service	Capacité à distribuer pendant les fenêtres prévues.	–	–	3
A-9	Valeur probante	Crédibilité d'un résultat d'investigation.	–	3	–

Confidentialité (C), intégrité (I), disponibilité (D) : 1 faible, 2 moyen, 3 critique.

ID	Objectif de sécurité	Actifs
OS-1	Avant l'épreuve, un sujet n'est lisible que par son auteur et ses destinataires.	A-1, A-2
OS-2	L'intégrité des sujets et des copies exactes est vérifiée par des condensés et preuves détachées ; les transformations de documents sont traitées à part.	A-1, A-2
OS-3	Un exemplaire divulgué peut être rattaché à sa distribution.	A-2, A-3
OS-4	Le système s'abstient d'une attribution lorsqu'une preuve est contradictoire ou insuffisante analysé.	A-3, A-9
OS-5	L'identité est vérifiée avec une force proportionnée aux droits.	A-5
OS-6	Moindre privilège et séparation des tâches sensibles.	tous
OS-7	Une opération sensible est associée à un compte et à des traces scellées ; la non-répudiation juridique d'une personne n'est pas garantie.	A-6
OS-8	Le service reste utilisable pendant les fenêtres de distribution et se rétablit.	A-8
OS-9	Les données personnelles sont minimisées, pseudonymisées dans les marques, conservées pour une durée limitée.	A-7
OS-10	La sécurité repose sur le secret des clés, non sur celui des algorithmes.	A-4

3.3 Directives de sécurité

ID	Directive	Conséquence
DS-01	PWA/SPA, *middleware* Jakarta EE 11 sur WildFly 42 et Java 25.	DT-01, DT-02
DS-02	Le métier fait la part belle à la dissimulation de l'information, à proportion d'un trinôme.	Chapitre 5
DS-03	Les aspects de sécurité suivent l'agenda du cours ; la progression est suivie sur GitHub.	Itérations 1 à 5
DS-04	Loi organique n° 2004-63 : finalité déclarée, protection et durée de conservation limitée des données personnelles. Une refonte de cette loi est en cours d'examen : veille assurée.	Famille ES-PRV
DS-05	OWASP ASVS 5.0, niveau 2, comme référentiel de vérification ; NIST SP 800-63B-4 pour les authentifiants.	Référence de chaque famille
DS-06	Primitives cryptographiques normalisées uniquement [R3, R4].	ES-CRY-05

3.4 Décisions techniques figées

Les décisions laissées ouvertes dans la version 1.0 sont arrêtées. Toute modification passe par le processus du chapitre 10.

ID	Sujet	Décision
DT-01	Client	PWA React ; *service worker* limité aux ressources statiques.

ID	Sujet	Décision
DT-02	*Middleware*	Jakarta EE 11 sur WildFly 42 et Java 25, selon la consigne. WildFly 42 recommande Java 25 sans revendication de certification EE 11 sur ce JDK [R9] ; tests de non-régression applicatifs imposés.
DT-03	Base de données	PostgreSQL 18 sur un hôte distinct, accès JDBC par Jakarta Persistence ; rôles à privilèges réduits.
DT-04	Stockage des fichiers	Système de fichiers privé hors racine web ; fichiers chiffrés, nommés par UUID.
DT-05	Mots de passe	Argon2id (RFC 9106) : $m = 65\,536$ Kio, $t = 3$, $p = 4$, sel de 16 octets, empreinte de 32 octets, format PHC ; Bouncy Castle dans un `IdentityStore` Jakarta Security.
DT-06	Cryptographie	AES-256-GCM (*nonce* de 96 bits, étiquette de 128 bits) ; HKDF-SHA-256 ; Ed25519 ; SHA-256 et HMAC-SHA-256 ; API JCA de Java 25.
DT-07	Clés	*Credential store* Elytron de WildFly, hors dépôt, lisible par NC-6 seul.
DT-08	Transport	TLS 1.3 uniquement, côté client et vers PostgreSQL ; HSTS.
DT-09	Session et accès	Session côté serveur, cookie `__Host-EGSESSION`, jeton anti-CSRF ; TOTP (RFC 6238) pour l'auditeur et l'administrateur ; RBAC à quatre rôles et contrôle par objet. Révisable après le chapitre 4 du cours.
DT-10	*Fingerprinting*	Décalage inter-mots sur PDF textuel admissible (PDFBox 3.0.x et opérateurs PDF), $\Delta = 0{,}40$ pt ; 64 bits, au moins 192 positions réelles sur le PDF complet, code continu entre pages, détection informée. Résistance à la collusion non garantie.
DT-11	*Watermarking*	DWT de Haar à un niveau, DCT 8×8, modulation QIM [R7] dans le bandeau d'en-tête ; charge de 48 bits ; détection aveugle.
DT-12	Stéganographie	*LSB matching* sur sceau PNG 256×256 : placement pseudo-aléatoire avec clé et nonce dédiés ; manifeste Ed25519 signé puis AES-GCM chiffré ; authenticité du manifeste seulement.
DT-13	Journal d'audit	Table chaînée SHA-256 avec numéros de séquence et ancres quotidiennes Ed25519 exportées hors de la base.
DT-14	Anti-automatisation	Défi ALTCHA (preuve de travail) et verrouillage progressif.
DT-15	Outils de test	JUnit 5, REST Assured, ArchUnit, Playwright, OWASP ZAP, `testssl.sh`, `gitleaks`, OWASP Dependency-Check, banc d'évaluation du marquage.

4. Besoins fonctionnels

4.1 Cas d'utilisation

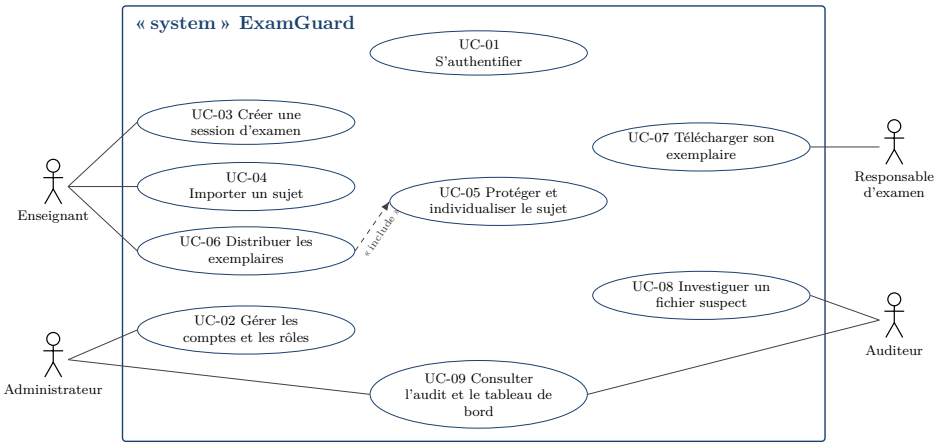


FIGURE 4.1 – Cas d'utilisation d'ExamGuard. Tous incluent UC-01 ; UC-05 est exécuté par le système.

4.2 Exigences fonctionnelles

Les identifiants de la version 1.0 sont conservés ; les énoncés sont précisés. La colonne UC rattache chaque exigence à son cas d'utilisation.

ID	Exigence	Description	UC	P	It.
F-01	Authentification	Le système authentifie chaque utilisateur par identifiant et mot de passe, complétés d'un code TOTP pour l'auditeur et l'administrateur.	01	P1	2
F-02	Gestion des comptes	L'administrateur crée, modifie, désactive et consulte les comptes. Il n'existe pas d'inscription libre.	02	P1	2
F-03	Gestion des rôles	Chaque compte porte un rôle unique parmi : administrateur, enseignant, responsable d'examen, auditeur.	02	P1	2
F-04	Création d'une session	L'enseignant crée une session en renseignant intitulé, matière, date de l'épreuve, date d'ouverture et date de clôture de la distribution.	03	P1	1
F-05	Importation du sujet	L'enseignant dépose un sujet au format PDF d'au plus 20 Mio et 50 pages. Un sujet par session ; un nouveau dépôt crée une nouvelle version.	04	P1	1
F-06	Condensé de l'original	Le système calcule le condensé SHA-256 du sujet à l'import, le conserve et l'affiche à l'enseignant.	04	P1	1
F-07	Consultation des sessions	L'enseignant consulte ses sessions ; le responsable, celles où il est destinataire ; l'auditeur, toutes, en lecture seule.	03	P1	2
F-08	Stéganographie	Le système dissimule dans le sceau PNG de chaque exemplaire le manifeste de distribution, signé puis chiffré, par *LSB matching*.	05	P1	1
F-09	Extraction du manifeste	Le système extrait, déchiffre et vérifie le manifeste dissimulé dans un fichier soumis à investigation.	08	P1	3

ID	Exigence	Description	UC	P	It.
F-10	*Watermarking*	Le système insère dans le bandeau d'en-tête de chaque page un filigrane invisible de 48 bits identifiant l'examen et, en pied de page, la mention visible « Exemplaire individualisé – diffusion restreinte ».	05	P1	1
F-11	*Fingerprinting*	Le système code dans l'espacement inter-mots de chaque exemplaire une empreinte de 64 bits propre à la distribution.	05	P1	1
F-12	Destinataires	L'enseignant associe de 1 à 50 responsables d'examen à une session.	06	P1	2
F-13	Génération des exemplaires	Le système produit un exemplaire par destinataire en appliquant F-08, F-10 et F-11, en 10 s au plus pour un sujet de 10 pages.	05	P1	1
F-14	Distribution	L'enseignant valide la distribution ; les exemplaires deviennent téléchargeables à la date d'ouverture. Une distribution validée n'est plus modifiable.	06	P1	2
F-15	Téléchargement	Le responsable télécharge son exemplaire entre l'ouverture et la clôture, au plus 3 fois ; un reçu est conservé.	07	P1	2
F-21	Révocation	L'enseignant révoque une distribution avant la clôture ; l'exemplaire n'est plus téléchargeable.	06	P2	2
F-16	Investigation	L'auditeur soumet un fichier suspect (PDF, PNG ou JPEG). Le système exécute quatre analyses : comparaison du condensé, détection du filigrane, décodage de l'empreinte, extraction du manifeste.	08	P1	3
F-20	Rapport d'investigation	Le système produit un rapport indiquant le résultat de chaque analyse, la distribution correspondante le cas échéant et un niveau de confiance (section 5.3).	08	P1	3
F-17	Journalisation	Le système enregistre les opérations sensibles énumérées par ES-JRN-01.	09	P1	3
F-18	Historique	L'auditeur et l'administrateur consultent le journal, filtré par période, acteur et type d'action.	09	P2	3
F-19	Tableau de bord	Chaque utilisateur dispose d'une vue de synthèse limitée à ses droits : sessions, état des distributions, alertes pour l'administrateur.	09	P2	3

4.3 Matrice des droits

La matrice suivante est la référence du contrôle d'accès (ES-AUZ-01). Toute case vide est une interdiction.

Opération	Enseignant	Responsable	Auditeur	Admin.
Gérer les comptes et les rôles				✓
Créer ou modifier une session	ses sessions			
Déposer ou télécharger un sujet original	ses sessions			
Désigner les destinataires, distribuer, révoquer	ses sessions			
Télécharger un exemplaire		le sien		
Consulter les sessions et les distributions	ses sessions	les siennes	toutes	
Lancer une investigation, lire un rapport			✓	
Consulter le journal d'audit et les alertes			✓	✓

Table 4.2 – Matrice des droits par rôle

5. Mécanismes de dissimulation

Les trois mécanismes sont le cœur métier d'ExamGuard. Ce chapitre fixe leur rôle, leurs algorithmes et leurs paramètres ; les étapes détaillées d'insertion et de détection figurent dans l'annexe A. Les seuils de qualité et de robustesse sont des exigences de la famille ES-DIS (chapitre 8).

5.1 Trois couches complémentaires

Chaque exemplaire porte trois marques indépendantes, qui répondent à trois questions différentes et ne cèdent pas aux mêmes attaques : c'est la défense en profondeur appliquée à la traçabilité.

	Watermarking	***Fingerprinting***	**Stéganographie**
Question	De quel examen provient ce fichier ?	De quelle distribution provient cet exemplaire ?	Ce fichier est-il un exemplaire authentique et intact ?
Algorithme	DWT de Haar (1 niveau), DCT 8×8, modulation QIM, pas $\Delta_q = 40$	Décalage des mots de $\pm\Delta$, $\Delta = 0{,}40$ pt, longueur des lignes inchangée	*LSB matching*, parcours pseudo-aléatoire piloté par ChaCha20
Support	Bandeau d'en-tête 1600×192 de chaque page	Texte du sujet : un mot intérieur sur deux est porteur	Sceau PNG 256×256 en dernière page
Charge	48 bits : identifiant d'examen (32) et CRC-16 ; 25 répétitions	64 bits : identifiant de distribution (48) et CRC-16 ; 3 répétitions au moins	Manifeste signé Ed25519 puis chiffré AES-256-GCM : 173 octets, 0,70 % des composantes
Détection	Aveugle, par vote majoritaire	Informée (l'original est conservé), par vote majoritaire	Avec les clés ; étiquette GCM puis signature
Propriété	Robustesse *visée* sur le corpus JPEG/échelle	Réenregistrement du PDF à démontrer ; collusion non garantie	Fragile : modification *de la charge* détectée, pas du PDF entier
Cède à	Suppression du bandeau	Recomposition ou ressaisie du texte	Toute recompression de l'image

Table 5.1 – Rôles, algorithmes et paramètres des trois mécanismes

Les identifiants portés par les marques sont pseudonymes : ils sont calculés par HMAC-SHA-256 à partir d'une clé, n'exposent pas directement le nom ou l'adresse du destinataire, mais restent des données pseudonymes, rattachables à une personne via la base ; ils doivent donc être protégés comme des données personnelles et ne sont pas prévisibles sans cette clé, ce qui empêche de fabriquer l'empreinte d'un autre destinataire. Un sujet doit offrir au moins 192 mots porteurs, soit environ 384 mots de texte courant ; en deçà, il est refusé (ES-VAL-04). Le manifeste contient les identifiants de l'examen et de la distribution, l'identifiant d'empreinte, l'horodatage et le condensé SHA-256 de l'original.

5.2 Clés et principe de Kerckhoffs

Clé	Origine	Usage unique
KEK	256 bits aléatoires, *credential store*	Enveloppe des clés de données (une par fichier).
K_m	256 bits aléatoires, *credential store*	Clé maîtresse de marquage ; jamais utilisée directement.
$K_{wm,id}$, $K_{wm,pos}$, $K_{st,d}$, $K_{enc,d}$	HKDF-SHA-256(K_m, domaines distincts ; `examId` et `distributionId` pour les deux dernières)	HMAC d'examen ; parcours QIM ; placement du sceau et AES-GCM du manifeste, séparés par copie. Le détecteur essaie au plus 50 candidats autorisés.
$K_{fp,e}$	HKDF-SHA-256(K_m, étiquette, examen)	Identifiants d'empreinte d'un examen.
SK_{man}, SK_{file}, SK_{recu}, SK_{ancre}	Quatre paires de clés Ed25519 indépendantes, conservées dans le *credential store*	Signatures respectives des manifestes, des enregistrements détachés des PDF finaux, des reçus et des ancres d'audit. Identifiants/version et clés publiques vérifiables séparément.

Contrat de dérivation reproductible. La notation HKDF(K_m, *ctx*) représente HKDF-SHA-256 avec $IKM = K_m$, sel public fixe SHA-256(`"ExamGuard/HKDF/v1"`), *info* = Encode(*ctx*) (type, longueur et valeur de chaque champ, ordre déterministe) et longueur de sortie $L = 32$ octets. Les identifiants `examId` et `distributionId` sont des UUID encodés sur 16 octets ; le numéro de version de clé permet de maintenir les anciens secrets pendant la durée légale de vérification. Les quatre clés Ed25519 sont distinctes, et chaque charge signée commence par un domaine canonique (`EG/MAN/1`, `EG/FILE/1`, `EG/RECU/1`, `EG/ANCHOR/1`).

Une application de dissimulation s'expose à la critique de la sécurité par l'obscurité. ExamGuard y répond par le principe de Kerckhoffs (OS-10) : les algorithmes et leurs paramètres sont publics ; seules les clés sont secrètes. Sans K_m, un attaquant ne peut ni localiser le manifeste, ni le lire, ni fabriquer une empreinte valide. Il peut tenter d'effacer les marques : ce risque est traité par la redondance des trois couches et déclaré au chapitre 11.

5.3 Rapport d'investigation

Le verdict se fonde sur des *preuves distinctes*. Un manifeste valide signé Ed25519 prouve l'intégrité de ses champs, non celle de toutes les pages. Le contrôle SHA-256 de l'exemplaire final et sa signature sont conservés *hors du PDF*, pour éviter de signer circulairement un fichier qui contiendrait lui-même sa signature. En cas de réenregistrement du document, le hash binaire change normalement ; seuls les signaux du marquage sont alors analysés. L'annexe A décrit le protocole et les limites de la preuve.

Niveau	Condition technique vérifiée	Conclusion affichée
Exact	SHA-256 du fichier suspect identique à celui d'un exemplaire final dont l'enregistrement détaché Ed25519 est valide.	Exemplaire binaire identifié ; pas de conclusion sur l'auteur de la fuite.
Concordant	Manifeste valide, fingerprint (HMAC attendu) du même `distributionId`, filigrane d'examen non contradictoire.	Distribution d'origine probable, avec réserves et examen humain.
Indice isolé	Un unique marqueur de distribution valide, sans corroboration cryptographique indépendante.	Hypothèse d'investigation, aucune désignation ferme.
Examen seul	Filigrane d'examen valide, aucune autre preuve exploitable.	Examen identifié, aucune distribution désignée.
Indéterminé	Marques absentes, corrompues, ambiguës ou contradictoires ; indice de collusion.	Aucune distribution désignée ; manipulation possible.

Règle non négociable : ni le CRC-16 ni un marqueur copiable ne fondent seuls une attribution définitive. Le logiciel ne peut déterminer qui a matériellement divulgué le document et n'émet pas de conclusion disciplinaire. L'objectif expérimental de zéro fausse désignation concerne strictement le corpus testé, pas tous les adversaires possibles.

Les seuils ES-DIS sont évalués sur un corpus versionné, comprenant des cas positifs, des copies non marquées, des variantes transformées, des compositions croisées (sceau A / corps B), des collusions de plusieurs exemplaires et des PDF partiellement supprimés. Les valeurs observées sont distinctes des seuils cibles et sont archivées.

6. Cas d'abus et cas d'utilisation de sécurité

6.1 Méthode et acteurs malveillants

Les cas d'abus ont été établis selon les huit étapes du cours : *brainstorming*, analyse des cas d'utilisation, adoption du point de vue de l'adversaire, identification des acteurs malveillants, spécification, recherche d'au moins un cas d'abus par cas d'utilisation, contrôle de la granularité puis de l'exhaustivité. Trois profils sont retenus : l'**attaquant externe**, sans compte ; le **destinataire indélicat**, responsable d'examen légitime qui veut divulguer un sujet sans être identifié ou faire accuser un tiers ; l'**interne privilégié** (administrateur de l'application, de la base ou du système) qui abuse de ses droits.

6.2 Diagrammes

Ellipses blanches : cas d'utilisation ; noires : cas d'abus ; vertes : cas d'utilisation de sécurité. Flèches rouges : « threatens » ; vertes : « mitigates » ; grises : « include ».

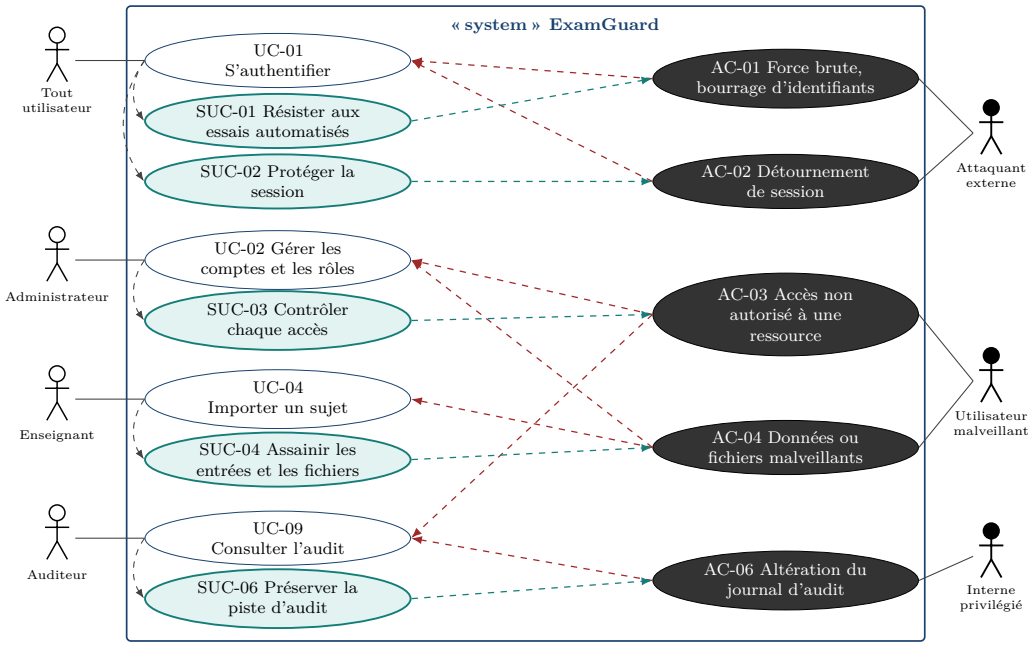


FIGURE 6.1 – Cas d'abus et de sécurité – accès et plateforme

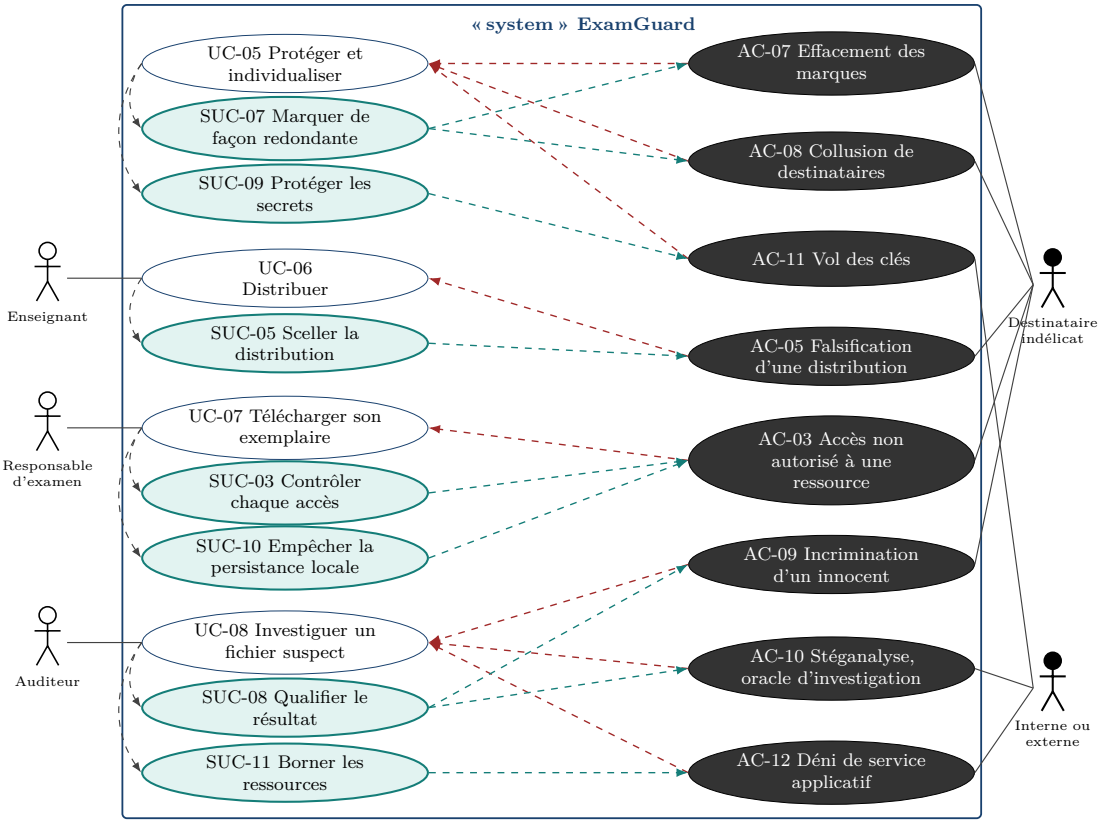


FIGURE 6.2 – Cas d'abus et de sécurité – sujet, distribution et investigation

Chaque cas d'utilisation est menacé par au moins un cas d'abus, et chaque cas d'abus est atténué par au moins un cas d'utilisation de sécurité.

Cas d'utilisation	**Cas d'abus « threatens »**	**Cas de sécurité « mitigates »**
UC-01 S'authentifier	AC-01, AC-02, AC-04, AC-12	SUC-01, SUC-02, SUC-04, SUC-11
UC-02 Gérer les comptes et les rôles	AC-03, AC-04	SUC-03, SUC-04
UC-03 Créer une session d'examen	AC-03, AC-04	SUC-03, SUC-04
UC-04 Importer un sujet	AC-04	SUC-04
UC-05 Protéger et individualiser	AC-07, AC-08, AC-11, AC-12	SUC-07, SUC-09, SUC-11
UC-06 Distribuer les exemplaires	AC-05	SUC-05
UC-07 Télécharger son exemplaire	AC-03, AC-05, AC-07	SUC-03, SUC-05, SUC-07, SUC-10
UC-08 Investiguer un fichier suspect	AC-03, AC-09, AC-10, AC-12	SUC-03, SUC-08, SUC-09, SUC-11
UC-09 Consulter l'audit	AC-03, AC-06	SUC-03, SUC-06

TABLE 6.1 – Couverture des cas d'utilisation par les cas d'abus et de sécurité

6.3 Fiches des cas d'abus

Les fiches reprennent le gabarit du cours. Les champs communs à toutes sont donnés une fois. *Environnement de développement* : PWA React, Jakarta EE 11 sur WildFly

42 et Java 25, PostgreSQL 18. *Périmètre* : application ExamGuard. *Parties prenantes* : l'établissement, qui supporte une fuite ou une accusation erronée, et les utilisateurs mis en cause par les traces. *Profils des acteurs malveillants* : section précédente.

AC-01 – Force brute et bourrage d'identifiants			
Priorité, sophistication	Élevée, faible	**Attributs affectés**	C, I
Acteur, droits	Attaquant externe, NC-0	**Point d'entrée**	API de connexion
Description	L'attaquant soumet en masse des couples identifiant et mot de passe, tirés de dictionnaires ou de bases divulguées, ou hameçonne un utilisateur, jusqu'à ouvrir une session.		
Préconditions, hypothèses	Les identifiants sont des adresses institutionnelles devinables ; des utilisateurs réutilisent leurs mots de passe.		
Postcondition si succès	Session ouverte au nom d'un enseignant ou d'un responsable : accès aux sujets ou à un exemplaire.		
Recommandation architecturale	Hachage coûteux en mémoire, limitation de débit, preuve de travail, second facteur pour les rôles sensibles, réponses indistinctes.		
Cas menacés	UC-01	**Menaces, parade**	M-01 ; SUC-01

AC-02 – Détournement de session			
Priorité, sophistication	Élevée, moyenne	**Attributs affectés**	C, I
Acteur, droits	Attaquant externe, NC-0	**Point d'entrée**	Navigateur de la victime, réseau
Description	L'attaquant obtient ou impose l'identifiant de session d'une victime (script injecté, fixation, écoute du réseau) ou fait émettre par son navigateur une requête modifiante à son insu.		
Préconditions, hypothèses	La victime a une session ouverte et visite un contenu contrôlé par l'attaquant, ou utilise un réseau qu'il observe.		
Postcondition si succès	L'attaquant agit avec les droits de la victime, qui est mise en cause par les traces.		
Recommandation architecturale	Identifiant de session inaccessible au script et renouvelé à la connexion, jeton anti-CSRF, transport chiffré exclusif, politique de sécurité du contenu.		
Cas menacés	UC-01 et suivants	**Menaces, parade**	M-02, M-03 ; SUC-02

AC-03 – Accès non autorisé à une ressource ou à une fonction			
Priorité, sophistication	Élevée, faible	**Attributs affectés**	C, I
Acteur, droits	Utilisateur authentifié, NC-2 ou NC-3	**Point d'entrée**	API de téléchargement, d'administration, d'investigation ; poste partagé
Description	Un utilisateur remplace l'identifiant de son exemplaire par celui d'un tiers, appelle directement une fonction réservée à un autre rôle, ou retrouve un exemplaire resté dans le navigateur d'un poste partagé.		
Préconditions, hypothèses	Compte valide ; identifiants prévisibles, contrôle fait côté client ou oublié sur un point d'entrée, réponses de l'API mises en cache.		
Postcondition si succès	Obtention d'un exemplaire marqué au nom d'un tiers (voir AC-09), création d'un compte privilégié, lecture du journal.		
Recommandation architecturale	Refus par défaut, contrôle par rôle et par objet à chaque requête, identifiants non devinables, aucune donnée confidentielle en cache.		
Cas menacés	UC-02, 03, 07, 08, 09	**Menaces, parade**	M-04 à M-06 ; SUC-03, SUC-10

AC-04 – Dépôt de données ou de fichiers malveillants			
Priorité, sophistication	Élevée, moyenne	**Attributs affectés**	C, I, D
Acteur, droits	Externe ou utilisateur, NC-0 à NC-4	**Point d'entrée**	Tout champ ; import ; investigation
Description	L'attaquant insère dans un champ ou un paramètre des données interprétées comme du code (fragment de requête, script, saut de ligne destiné au journal), ou dépose un fichier forgé : PDF à contenu actif, structure visant l'analyseur.		
Préconditions, hypothèses	Une entrée est utilisée sans validation ni encodage, ou une bibliothèque de traitement est vulnérable.		
Postcondition si succès	Lecture ou modification de la base avec les droits de NC-7 ; exécution de code sous NC-6 ; script exécuté chez un auditeur.		
Recommandation architecturale	Validation par liste d'autorisation, requêtes paramétrées, contrôle du contenu réel des fichiers, rejet du contenu actif, erreurs génériques, dépendances suivies.		
Cas menacés	UC-01 à UC-04, UC-08	**Menaces, parade**	M-07, M-08 ; SUC-04

AC-05 – Falsification ou répudiation d'une distribution			
Priorité, sophistication	Moyenne, moyenne	**Attributs affectés**	I, non-répudiation
Acteur, droits	Utilisateur, NC-2 ou NC-3	**Point d'entrée**	API de distribution, base
Description	L'attaquant modifie après coup le destinataire ou l'empreinte associés à un exemplaire, rejoue une requête de distribution, ou nie avoir téléchargé l'exemplaire qui a fuité.		
Préconditions, hypothèses	Les distributions sont modifiables ; les téléchargements ne laissent pas de trace opposable.		
Postcondition si succès	La table des distributions ne reflète plus la réalité : une fuite est attribuée à un tiers ou n'est plus attribuable.		
Recommandation architecturale	Distributions immuables, manifeste signé, reçu de téléchargement signé, journalisation préalable à la confirmation.		
Cas menacés	UC-06, UC-07	**Menaces, parade**	M-09, M-10 ; SUC-05

AC-06 – Altération du journal d'audit			
Priorité, sophistication	Moyenne, moyenne	**Attributs affectés**	I, non-répudiation
Acteur, droits	Interne privilégié, NC-5, NC-9	**Point d'entrée**	Base de données
Description	Après une opération illégitime, un acteur aux droits étendus supprime ou modifie les entrées qui le concernent, directement dans la base.		
Préconditions, hypothèses	Le journal est une table ordinaire, modifiable ; aucune vérification d'intégrité n'est faite.		
Postcondition si succès	Disparition des traces sans que l'altération soit détectée.		
Recommandation architecturale	Journal en ajout seul, entrées chaînées, ancre signée, vérification quotidienne. L'altération par NC-9 ne peut être empêchée : elle doit être détectée.		
Cas menacés	UC-09	**Menaces, parade**	M-11 ; SUC-06

AC-07 – Effacement des marques			
Priorité, sophistication	Élevée, faible à moyenne	**Attributs affectés**	I (traçabilité), C
Acteur, droits	Destinataire indélicat, NC-2	**Point d'entrée**	Hors ligne, sur l'exemplaire
Description	Connaissant l'algorithme, qui est public, le destinataire uniformise l'espacement des mots, retire le bandeau et le sceau, ou plus simplement photographie son écran ou imprime puis numérise l'exemplaire, avant de le divulguer.		
Préconditions, hypothèses	Possession légitime d'un exemplaire ; aucun contrôle technique n'est possible sur le poste du destinataire.		
Postcondition si succès	Fichier divulgué ne portant plus de marque nominative exploitable : la fuite n'est attribuable qu'à l'examen.		
Recommandation architecturale	Trois marques indépendantes sur trois supports ; filigrane robuste à la compression ; mention visible et information préalable. Risque résiduel déclaré au chapitre 11.		
Cas menacés	UC-05, UC-07	**Menaces, parade**	M-12, M-13 ; SUC-07

AC-08 – Collusion de destinataires			
Priorité, sophistication	Moyenne, moyenne	**Attributs affectés**	I (traçabilité)
Acteur, droits	Deux destinataires, NC-2	**Point d'entrée**	Hors ligne
Description	Deux destinataires comparent leurs exemplaires, repèrent les mots dont la position diffère et fabriquent un exemplaire mixte dont l'empreinte ne correspond à aucun d'eux.		
Préconditions, hypothèses	Deux exemplaires du même sujet sont réunis.		
Postcondition si succès	L'empreinte décodée est invalide, ou coïncide avec celle d'un troisième destinataire, innocent.		
Recommandation architecturale	CRC comme contrôle d'erreur ; vérification des HMAC candidats ; abstention si collusion suspectée, car le CRC ne protège pas contre une attaque volontaire et le système s'abstient de désigner.		
Cas menacés	UC-05, UC-07	**Menaces, parade**	M-14 ; SUC-07, SUC-08

AC-09 – Incrimination d'un innocent			
Priorité, sophistication	Élevée, élevée	**Attributs affectés**	I (valeur probante)
Acteur, droits	Destinataire indélicat ou interne	**Point d'entrée**	Téléchargement, base
Description	L'attaquant veut qu'une investigation désigne un tiers : il divulgue l'exemplaire de ce tiers obtenu par AC-02 ou AC-03, fabrique un fichier portant l'empreinte d'autrui, ou modifie la table des distributions.		
Préconditions, hypothèses	Accès à l'exemplaire d'un tiers, aux clés ou à la base ; le rapport est lu comme une preuve d'identité.		
Postcondition si succès	Sanction d'une personne étrangère à la fuite ; perte de crédibilité du système.		
Recommandation architecturale	Empreintes non prévisibles sans clé ; abstention si les marques sont invalides ou contradictoires ; rapport gradué ; reçus de téléchargement.		
Cas menacés	UC-08	**Menaces, parade**	M-15 ; SUC-08

AC-10 – Stéganalyse et oracle d'investigation			
Priorité, sophistication	Moyenne, élevée	**Attributs affectés**	C
Acteur, droits	Destinataire indélicat, NC-2	**Point d'entrée**	Hors ligne ; investigation
Description	L'attaquant analyse statistiquement le sceau pour établir qu'il contient un message, tente de le lire, ou soumet des variantes de son fichier à l'investigation pour apprendre quelle transformation efface les marques.		
Préconditions, hypothèses	L'insertion laisse une signature statistique, ou l'investigation est accessible sans restriction.		
Postcondition si succès	L'attaquant sait quelles marques retirer, ou lit le contenu du manifeste.		
Recommandation architecturale	Taux d'insertion faible, parcours à clé, charge chiffrée et pseudonyme ; investigation réservée à l'auditeur, limitée en débit, journalisée.		
Cas menacés	UC-05, UC-08	**Menaces, parade**	M-16 ; SUC-08, SUC-09

AC-11 – Vol des clés			
Priorité, sophistication	Élevée, moyenne	**Attributs affectés**	C, I
Acteur, droits	Externe ou interne, NC-10	**Point d'entrée**	Dépôt Git, hôte, sauvegardes
Description	L'attaquant récupère une clé dans l'historique du dépôt, un fichier de configuration, une image ou une sauvegarde, puis déchiffre les sujets ou forge des marques et des signatures.		
Préconditions, hypothèses	Une clé a été écrite en clair hors du magasin prévu.		
Postcondition si succès	Tous les sujets stockés sont lisibles ; toute marque peut être forgée.		
Recommandation architecturale	Clés dans un magasin dédié hors dépôt, une clé par usage, détection de secrets en intégration continue, rotation, sauvegardes chiffrées.		
Cas menacés	Tous	**Menaces, parade**	M-17 ; SUC-09

AC-12 – Déni de service applicatif			
Priorité, sophistication	Élevée, faible	**Attributs affectés**	D
Acteur, droits	Externe ou utilisateur	**Point d'entrée**	Connexion, génération, investigation
Description	L'attaquant déclenche en rafale les opérations les plus coûteuses : connexions (chaque hachage mobilise 64 Mio), générations d'exemplaires, investigations, ou dépose une image dont la décompression occupe plusieurs gigaoctets.		
Préconditions, hypothèses	Aucune borne de débit, de durée, de taille ni de simultanéité.		
Postcondition si succès	Service indisponible pendant une fenêtre de distribution, la veille d'une épreuve.		
Recommandation architecturale	Limitation de débit, files bornées, durée maximale par traitement, nombre de hachages simultanés plafonné.		
Cas menacés	UC-01, UC-05, UC-08	**Menaces, parade**	M-18 ; SUC-11

6.4 Cas d'utilisation de sécurité

Un cas d'utilisation de sécurité décrit ce que le système garantit pour contrecarrer un cas d'abus. Conformément au cours, il ne nomme aucun mécanisme : les algorithmes

figurent dans les exigences qui en sont dérivées. Les fiches détaillées (déroulements nominal et alternatifs, exceptions) figurent dans l'annexe D.

ID	Nom	Atténue	Ce que le système garantit	Exigences dérivées
SUC-01	Résister aux essais automatisés	AC-01	L'identité de l'acteur est vérifiée ; les essais en masse sont coûteux, lents et bornés.	ES-AUT-01 à 05
SUC-02	Protéger la session	AC-02	Seul le navigateur authentifié agit dans la session, et à l'initiative de l'utilisateur.	ES-SES-01 à 03, ES-CRY-01, ES-INT-04
SUC-03	Contrôler chaque accès	AC-03	Toute requête est contrôlée sur le droit d'exécuter la fonction et sur le droit d'accéder à l'objet.	ES-AUZ-01 à 05, ES-ERR-02
SUC-04	Assainir les entrées et les fichiers	AC-04	Une donnée ou un fichier n'est utilisé qu'après contrôle ; un rejet ne révèle rien du système.	ES-VAL-01 à 03, ES-VAL-05, ES-ERR-01, ES-CFG-03
SUC-05	Sceller la distribution	AC-05	Une distribution est figée ; sa création et chaque téléchargement sont prouvables.	ES-INT-01 à 03, ES-NRP-01, ES-NRP-02
SUC-06	Préserver la piste d'audit	AC-06	Toute modification, suppression ou insertion dans le journal est détectée, même par un acteur privilégié.	ES-JRN-01 à 04, ES-AUZ-05
SUC-07	Marquer de façon redondante	AC-07, AC-08	Chaque exemplaire porte plusieurs marques indépendantes et imperceptibles sur des supports différents.	ES-DIS-01, 02, 04, 05, ES-VAL-04, ES-PRV-03
SUC-08	Qualifier le résultat d'une investigation	AC-08, AC-09, AC-10	Une distribution n'est désignée que si les marques sont valides et concordantes ; la conclusion porte un niveau de confiance.	ES-DIS-03, ES-DIS-09, ES-DIS-10, ES-INT-02
SUC-09	Protéger les secrets	AC-10, AC-11	La confidentialité des sujets et la validité des marques reposent sur des secrets gardés en un lieu unique et remplaçables.	ES-CRY-02 à 06, ES-DIS-06 à 08, ES-DSP-04
SUC-10	Empêcher la persistance locale	AC-03	Aucune donnée confidentielle ne subsiste dans le navigateur après usage.	ES-CFG-01, ES-SES-02, ES-AUZ-04
SUC-11	Borner les ressources	AC-12	Le débit, la durée et la simultanéité des traitements coûteux sont plafonnés.	ES-DSP-01 à 03, ES-VAL-03, ES-VAL-05

6.5 Récits d'abus et récits de sécurité

Chaque couple de récits est une *issue* GitHub (`abuse-story`, `security-story`) ; une *issue* de sécurité n'est close que lorsque les tests des exigences liées réussissent.

Cas	Récit d'abus	Récit de sécurité
AC-01	En tant qu'attaquant externe, je veux essayer des milliers de mots de passe afin d'ouvrir la session d'un enseignant.	En tant qu'enseignant, je veux que mon compte résiste aux essais en masse afin que personne n'accède à mes sujets.
AC-02	En tant qu'attaquant, je veux voler le cookie de session d'un auditeur afin d'utiliser l'investigation.	En tant qu'auditeur, je veux que ma session ne puisse être ni lue ni réutilisée par un tiers.

Cas	Récit d'abus	Récit de sécurité
AC-03	En tant que responsable d'examen, je veux modifier l'identifiant dans l'adresse de téléchargement afin d'obtenir l'exemplaire d'un collègue.	En tant que responsable d'examen, je veux que mon exemplaire ne soit délivré qu'à moi afin de ne pas être accusé à tort.
AC-04	En tant qu'utilisateur malveillant, je veux déposer un PDF piégé ou injecter une requête afin de prendre le contrôle du serveur.	En tant qu'exploitant, je veux que toute entrée et tout fichier soient contrôlés avant usage.
AC-05	En tant que destinataire, je veux nier avoir téléchargé mon exemplaire afin d'échapper à une mise en cause.	En tant qu'auditeur, je veux un reçu vérifiable de chaque téléchargement.
AC-06	En tant qu'administrateur de la base, je veux supprimer la ligne du journal qui me concerne afin d'effacer ma trace.	En tant qu'auditeur, je veux que toute altération du journal soit détectée et localisée.
AC-07	En tant que destinataire, je veux uniformiser l'espacement des mots de mon exemplaire afin de le divulguer sans être identifié.	En tant qu'enseignant, je veux que chaque exemplaire porte plusieurs marques indépendantes afin qu'une fuite reste attribuable.
AC-08	En tant que destinataires complices, nous voulons mélanger nos exemplaires afin de produire une empreinte qui ne désigne aucun de nous.	En tant que destinataire innocent, je veux que le système s'abstienne plutôt que de me désigner sur la foi d'une marque invalide.
AC-09	En tant que destinataire, je veux divulguer un fichier portant l'empreinte d'un collègue afin de le faire accuser.	En tant que destinataire, je veux qu'un rapport indique son niveau de confiance et rappelle qu'il n'est qu'un indice.
AC-10	En tant que destinataire, je veux soumettre des variantes de mon fichier à l'investigation afin de savoir quand il n'est plus traçable.	En tant qu'établissement, je veux que l'investigation soit réservée à l'auditeur et limitée en débit.
AC-11	En tant qu'attaquant, je veux trouver une clé dans l'historique Git afin de déchiffrer les sujets.	En tant qu'équipe, nous voulons que l'intégration continue bloque tout secret poussé dans le dépôt.
AC-12	En tant qu'étudiant, je veux saturer le serveur la veille de l'épreuve afin de la faire reporter.	En tant qu'enseignant, je veux que la distribution reste possible pendant une tentative de saturation.

7. Modélisation des menaces

Le modèle de menaces suit le processus du cours : objectifs de sécurité (chapitre 3), revue de l'application, décomposition, identification des menaces par STRIDE et évaluation de risque suivant OWASP Risk Rating (vraisemblance et impact technique/métier). La décomposition complète (dépendances externes, points d'entrée, flux de données et frontières de confiance, profil de sécurité) figure dans l'annexe B.

7.1 Revue de l'application : déploiement

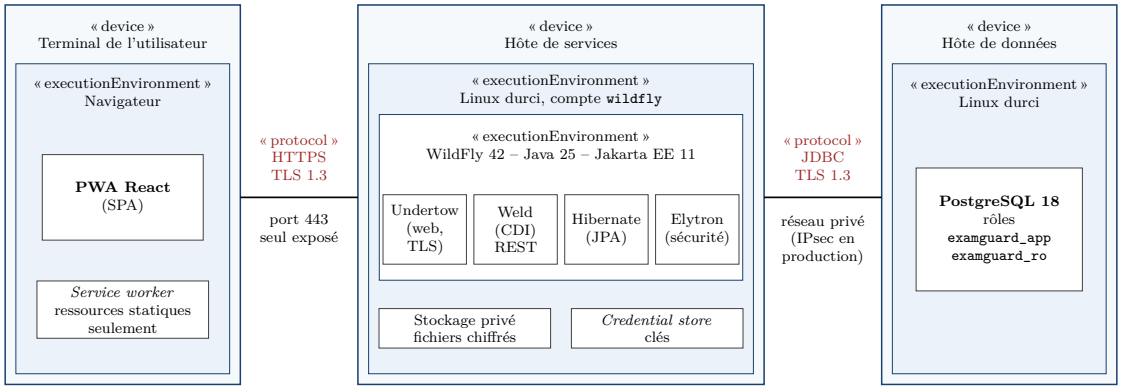


FIGURE 7.1 – Diagramme de déploiement et contraintes de sécurité des liens

7.2 Arbre d'attaque

L'objectif d'attaque qui concentre le risque propre à ExamGuard est de divulguer un sujet sans être identifié. Chaque feuille renvoie aux exigences qui la contrent ; l'arbre de l'objectif « faire désigner un innocent » figure dans l'annexe B.

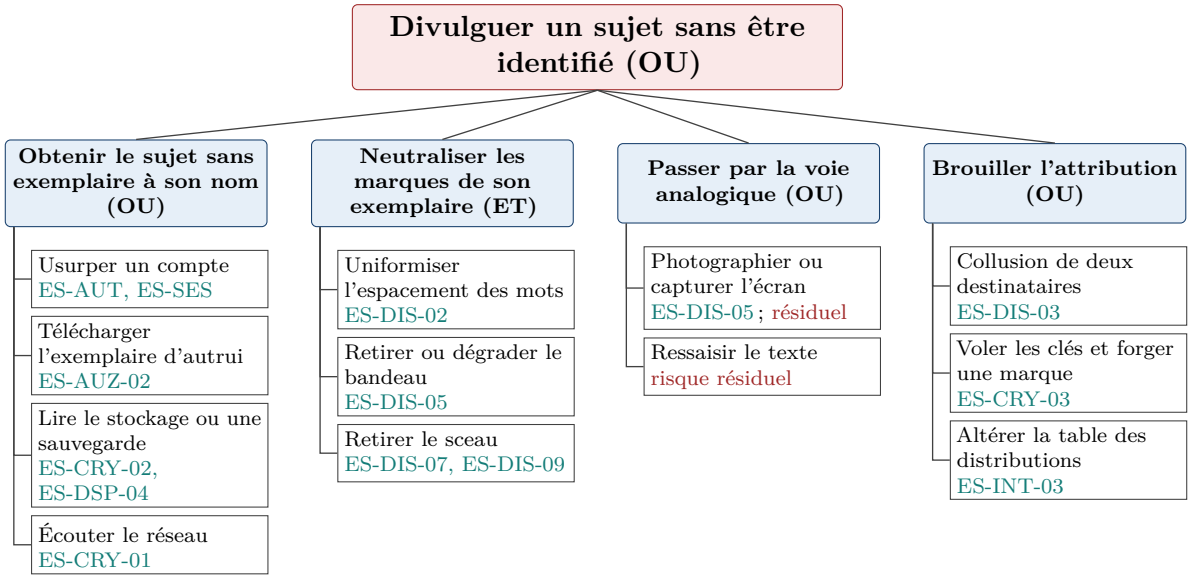


FIGURE 7.2 – Arbre d'attaque – divulguer un sujet sans être identifié

7.3 Identification et cotation des menaces

Les 18 scénarios sont classés par STRIDE, puis évalués avec *OWASP Risk Rating* [R8]. Le risque métier est prioritaire : fuite d'un sujet avant l'épreuve, accusation erronée, indisponibilité le jour de l'épreuve, compromission des preuves. Les paramètres ne décrivent *pas* des attaques réellement observées : ils sont des hypothèses initiales de revue à valider collectivement puis à mettre à jour après tests et retours.

Méthode reproductible. La vraisemblance L est la moyenne de huit facteurs notés de 0 à 9 : compétence, motivation, opportunité, taille du groupe, découvrabilité de la faiblesse, facilité d'exploitation, notoriété, probabilité de non-détection. Le dommage technique I_t est la moyenne des quatre impacts C, I, D, traçabilité ; le dommage métier I_m la moyenne des quatre facteurs financier, réputation, conformité, vie privée, adaptés au contexte universitaire. La gravité compare L et I_m (l'impact technique reste indiqué). Seuils OWASP : faible $[0, 3[$, moyen $[3, 6[$, élevé $[6, 9]$. La matrice OWASP donne, pour un impact élevé, respectivement moyen/élevé/critique quand la vraisemblance est faible/moyenne/élevée. L'annexe B fournit la valeur de *chacun* des 16 facteurs, ce qui rend le calcul auditable.

Pourquoi pas DREAD ? Les notes de dommages, reproductibilité, exploitabilité, nombre d'utilisateurs atteints et découvrabilité sont très dépendantes de l'évaluateur, n'isolent pas explicitement le coût métier, et la dimension découvrabilité double parfois l'exploitabilité. Le modèle est fréquemment jugé trop subjectif et peu reproductible. OWASP Risk Rating n'élimine pas le jugement expert, mais impose d'expliciter ses hypothèses, différencie probabilité et impacts, et prévoit la discussion avec le métier. CVSS reste réservé au score technique de vulnérabilités connues dans les dépendances et n'est pas notre modèle de risque institutionnel.

ID	STRIDE	Cible	Scénario contextualisé	Contre-mesures prévues	L	I_t	I_m	Risque	Prio
M-01	S	Authentification, A-5	L'attaquant ouvre une session au nom d'un utilisateur dont il a deviné ou obtenu le mot de passe. Dictionnaire, bourrage d'identifiants, hameçonnage.	ES-AUT-02 à 05	8.5	5.5	5.0	Élevée	P1
M-02	S, T	Sessions (A-5)	L'attaquant réutilise la session d'une victime ou fait émettre une requête par son navigateur. Script injecté, fixation de session, requête intersite (CSRF).	ES-SES-01 à 03, ES-INT-04	7.2	6.2	5.8	Élevée	P1
M-03	I	Flux réseau	Un tiers écoute les échanges entre le client et le serveur ou entre le serveur et la base. Écoute, rétrogradation du protocole.	ES-CRY-01	5.9	4.8	4.8	Moyenne	P2
M-04	I	Téléchargement, A-1, A-2	Un utilisateur obtient l'exemplaire ou le sujet d'un tiers. Substitution de l'identifiant dans la requête, énumération.	ES-AUZ-02, ES-AUZ-04	7.2	6.8	7.0	Critique	P1

ID	STRIDE	Cible	Scénario contextualisé	Contre-mesures prévues	L	I_t	I_m	Risque	Prio
M-05	E	Administration, investigation, audit	Un utilisateur exécute une fonction réservée à un autre rôle. Appel direct de l'API, modification de son propre rôle.	ES-AUZ-01, ES-AUZ-03, ES-ERR-02	7.4	7.0	6.8	Critique	P1
M-06	I	Client (PWA)	Un exemplaire subsiste dans le navigateur d'un poste partagé. Consultation du cache et du stockage local.	ES-CFG-01, ES-SES-02	6.4	3.8	4.0	Élevée	P1
M-07	T, E	Import, investigation	Un fichier forgé ou une bibliothèque vulnérable permet d'exécuter du code sur le serveur. PDF malformé, contenu actif, vulnérabilité publiée.	ES-VAL-03, ES-VAL-05, ES-CFG-03	7.1	8.5	7.2	Critique	P1
M-08	T, I	Base de données	L'attaquant lit ou modifie la base par une entrée interprétée comme une requête ; les erreurs le guident. Injection SQL ou JPQL, requêtes malformées.	ES-VAL-01, ES-VAL-02, ES-ERR-01, ES-AUZ-05	7.4	8.0	7.8	Critique	P1
M-09	T	Distributions (A-3)	Le destinataire ou l'empreinte d'une distribution est modifié après coup. Requête rejouée ou forgée, accès direct à la base.	ES-INT-02, ES-INT-03	4.8	6.2	7.2	Élevée	P1
M-10	R	Téléchargement	Un destinataire nie avoir téléchargé son exemplaire. Contestation en l'absence de preuve opposable.	ES-NRP-01, ES-NRP-02	7.0	5.2	5.0	Élevée	P1
M-11	T, R	Journal (A-6)	Un acteur privilégié supprime ou modifie des entrées du journal. Accès direct à la base.	ES-JRN-03, ES-AUZ-05	4.0	6.8	7.0	Élevée	P1
M-12	T	Exemplaire (A-2)	Le destinataire efface les marques de son exemplaire numérique avant de le divulguer. Uniformisation de l'espacement, retrait du bandeau et du sceau.	ES-DIS-02, ES-DIS-05, ES-DIS-07	7.1	6.0	6.8	Critique	P1
M-13	I	Exemplaire (A-2)	Le destinataire divulgue une photographie ou une numérisation de son exemplaire. Capture d'écran, photographie, impression puis numérisation.	ES-DIS-05, ES-PRV-03 ; résiduel	7.6	7.0	7.2	Critique	P1
M-14	T	Empreinte (A-2)	Deux destinataires fabriquent un exemplaire mixte. Comparaison de deux exemplaires, mélange des positions.	ES-DIS-03, ES-DIS-09	6.9	5.8	7.0	Critique	P1
M-15	S, R	Valeur probante (A-9)	L'investigation désigne une personne étrangère à la fuite. Divulgation de l'exemplaire d'autrui, marque forgée.	ES-DIS-03, ES-DIS-08, ES-DIS-09, ES-NRP-02	6.8	6.2	7.0	Critique	P1
M-16	I	Sceau, investigation	Un tiers détecte ou lit le manifeste dissimulé, ou utilise l'investigation pour tester l'effacement des marques. Analyse statistique, soumissions répétées.	ES-DIS-06, ES-DIS-07, ES-DIS-10	5.8	4.8	5.0	Moyenne	P2
M-17	I	Clés (A-4), stockage	Une clé est récupérée, ou les sujets sont lus sur le disque ou dans une sauvegarde. Historique Git, fichier de configuration, vol de support.	ES-CRY-02, ES-CRY-03, ES-DSP-04	5.4	8.0	8.0	Élevée	P1
M-18	D	Disponibilité (A-8)	L'attaquant épuise la mémoire ou le processeur du serveur. Rafales de connexions, de générations, d'investigations ; bombe de décompression.	ES-DSP-01, ES-DSP-02, ES-VAL-03	8.4	5.8	6.2	Critique	P1

8. Exigences de sécurité

Les 57 exigences sont regroupées en treize familles, qui couvrent les six types attendus. Chaque exigence nomme un mécanisme et un seuil, porte un critère de vérification (le test TS de même numéro), une priorité déterminée par le risque et ses dépendances, l'itération où elle est réalisée et son origine.

Famille	Intitulé	Type d'exigence	Nb	P1	P2	P3
ES-AUT	Identification et authentification	Identification et authentification	5	5	0	0
ES-SES	Gestion de session	Identification et authentification	3	3	0	0
ES-AUZ	Autorisation	Autorisation	5	4	1	0
ES-CRY	Confidentialité et cryptographie	Intégrité et confidentialité	6	5	1	0
ES-INT	Intégrité et authenticité	Intégrité et confidentialité	4	4	0	0
ES-NRP	Non-répudiation	Non-répudiation	2	2	0	0
ES-VAL	Validation des entrées et des fichiers	Intégrité et confidentialité	5	5	0	0
ES-DIS	Dissimulation de l'information	Intégrité et confidentialité	10	8	2	0
ES-JRN	Journalisation, audit, détection d'intrusion	Détection et audit	4	4	0	0
ES-ERR	Gestion des erreurs	Détection et audit	2	1	1	0
ES-DSP	Résilience et disponibilité	Résilience et disponibilité	4	2	2	0
ES-PRV	Protection des données personnelles	Intégrité et confidentialité	3	0	3	0
ES-CFG	Configuration, déploiement, chaîne logicielle	Résilience et disponibilité	4	2	2	0
		Total	**57**	**45**	**12**	**0**

TABLE 8.1 – Synthèse des familles d'exigences de sécurité

ID	Exigence	Critère de vérification (test)	P	It.	Origine
Identification et authentification (ES-AUT) – ASVS V6 – cours : chapitre 4					
ES-AUT-01	Aucune ressource sous `/api/` n'est accessible sans session authentifiée, hormis la connexion, le défi anti-automatisation et `/api/health`. Une requête non authentifiée reçoit 401 sans autre information.	Parcours automatisé de 100 % des routes du contrat OpenAPI sans session : 401 partout, hors exceptions.	1	2	AC-01, SUC-01
ES-AUT-02	Les mots de passe sont hachés par Argon2id (RFC 9106) : $m = 65\,536$ Kio, $t = 3$, $p = 4$, sel aléatoire de 16 octets, empreinte de 32 octets, format PHC. Ils ne sont jamais stockés ni journalisés en clair.	L'empreinte stockée commence par `$argon2id$v=19$m=65536,t=3,p=4$` ; deux hachages du même mot de passe diffèrent ; mot de passe sentinelle absent de la base et des journaux.	1	2	AC-01, M-01, DS-05
ES-AUT-03	Un mot de passe compte au moins 15 caractères (128 acceptés, Unicode compris), sans règle de composition ni expiration périodique ; il est refusé s'il figure dans une liste d'au moins 100 000 mots de passe compromis. Les comptes sont créés par l'administrateur seul ; le mot de passe initial, à usage unique, expire après 24 heures.	14 caractères → refus ; 15 → accepté ; mot de passe de la liste → refus ; aucune route d'inscription ; mot de passe initial utilisé après 24 heures → refus.	1	2	AC-01, M-01, DS-05
ES-AUT-04	L'auditeur et l'administrateur n'ouvrent une session qu'avec un code TOTP valide (RFC 6238 : 6 chiffres, 30 s, tolérance d'un pas), accepté une seule fois. Le secret TOTP est chiffré au repos par AES-256-GCM.	Connexion sans code → refus ; rejeu du même code → refus ; code vieux de deux pas → refus ; secret illisible en base.	1	2	AC-01, M-01, OS-5
ES-AUT-05	Après 3 échecs consécutifs, un défi ALTCHA est exigé ; après 5 échecs en 15 minutes, le compte est verrouillé 15 minutes, durée doublée à chaque récidive (24 heures au plus) ; une adresse IP est limitée à 10 tentatives par minute. Un échec produit la même réponse que le compte existe ou non.	6e essai, même avec le bon mot de passe → refus pendant 15 minutes ; 11e requête en une minute → 429 ; réponses identiques et écart des temps médians ≤ 50 ms sur 100 essais.	1	2	AC-01, AC-12, M-01
Gestion de session (ES-SES) – ASVS V7 – cours : chapitre 4					
ES-SES-01	L'identifiant de session comporte au moins 128 bits d'aléa et est renouvelé à l'authentification. Il est porté par le cookie `__Host-EGSESSION` (`Secure`, `HttpOnly`, `SameSite=Strict`) ; aucun jeton ne figure dans une URL ni dans le stockage du navigateur.	L'identifiant d'avant connexion est refusé après (401) ; attributs du cookie conformes ; `localStorage` et `sessionStorage` vides (Playwright).	1	2	AC-02, M-02
ES-SES-02	Une session expire après 15 minutes d'inactivité et au plus tard 8 heures après son ouverture ; la déconnexion l'invalide côté serveur.	Requête après 16 minutes → 401 ; cookie rejoué après déconnexion → 401.	1	2	AC-02, AC-03, M-06
ES-SES-03	Toute requête modifiante porte un en-tête `X-CSRF-Token` lié à la session, à défaut de quoi elle reçoit 403. Aucune opération modifiante n'est exposée en GET.	Requête sans jeton, puis avec le jeton d'une autre session → 403 ; aucun GET à effet de bord dans le contrat OpenAPI.	1	2	AC-02, M-02
Autorisation (ES-AUZ) – ASVS V8 – cours : chapitre 4					
ES-AUZ-01	L'accès est refusé par défaut : chaque méthode de ressource REST déclare les rôles autorisés, et la matrice des droits (tableau 4.2) est appliquée côté serveur. Toute combinaison non autorisée reçoit 403.	Test ArchUnit : 100 % des méthodes annotées ; test couvrant 100 % des cases vides de la matrice → 403.	1	2	AC-03, M-05

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-AUZ-02	Le contrôle est fait par objet : un responsable n'obtient que son exemplaire, un enseignant que ses sessions. La requête visant l'objet d'un tiers reçoit 404, comme pour un objet inexistant, et est journalisée. Les identifiants exposés sont des UUID version 4.	Deux comptes de même rôle demandent chacun l'objet de l'autre → 404 et entrée de journal ; réponse identique à celle d'un identifiant inexistant ; aucun identifiant séquentiel dans l'API.	1	2	AC-03, AC-09, M-04
ES-AUZ-03	Les tâches sont séparées : l'administrateur ne peut ni télécharger un fichier ni lancer une investigation ; l'auditeur ne peut rien modifier ; un compte porte un seul rôle.	Tests de la matrice ; attribution d'un second rôle → 400.	1	2	AC-03, M-05, OS-6
ES-AUZ-04	Un exemplaire n'est téléchargeable qu'entre l'ouverture et la clôture de la distribution, 3 fois au plus ; au-delà, 403 et alerte.	Téléchargement avant l'ouverture, après la clôture, 4e téléchargement → 403 et alerte R3.	2	2	AC-03, M-04
ES-AUZ-05	Le rôle PostgreSQL `examguard_app` possède seulement les autorisations indispensables, aucun DDL ni DELETE/UPDATE/TRUNCATE sur `audit_log`. La séparation d'un rôle de lecture d'audit est appliquée. Un superutilisateur BD reste capable de contourner les ACL ; les altérations sont détectées par ES-JRN-03 et ses ancres externes.	Avec le rôle applicatif : UPDATE/DELETE/TRUNCATE du journal et CREATE TABLE refusés. Avec un superutilisateur en test : les mutations sont détectées à la vérification de l'ancre externe.	1	3	AC-04, AC-06, M-08, M-11
Confidentialité et cryptographie (ES-CRY) – ASVS V11, V12, V14 – cours : chapitre 3					
ES-CRY-01	Seul TLS 1.3 est accepté, sur l'interface publique (avec `Strict-Transport-Security: max-age=31536000`) comme entre WildFly et PostgreSQL (`sslmode=verify-full`). PostgreSQL n'écoute sur aucune interface publique.	`testssl.sh` : TLS 1.3 seul ; connexion en TLS 1.2 → échec ; `pg_stat_ssl` : TLS 1.3 pour 100 % des connexions ; port 5432 fermé de l'extérieur.	1	1	AC-02, M-03
ES-CRY-02	Les sujets et les exemplaires sont chiffrés au repos par AES-256-GCM : *nonce* aléatoire de 96 bits unique, étiquette de 128 bits, une clé de données par fichier enveloppée par la KEK. Aucun fichier en clair n'est écrit sur disque, fichiers temporaires compris.	Recherche de `%PDF` dans les répertoires de stockage et temporaire : 0 résultat ; un octet modifié → déchiffrement refusé ; 10 000 *nonces* tous distincts.	1	1	AC-11, M-17
ES-CRY-03	La KEK, la clé maîtresse de marquage et les quatre clés privées de signature résident uniquement dans le *credential store* Elytron (hors dépôt, mode 600, compte `wildfly`). Aucun secret ne figure dans le dépôt, son historique ou une image ; la configuration propre à l'environnement est injectée au démarrage.	`gitleaks` sur tout l'historique : 0 détection, contrôle bloquant ; test de démarrage sur le mode et le propriétaire du fichier.	1	1	AC-11, M-17, OS-10
ES-CRY-04	Les clés d'usage sont dérivées de la clé maîtresse par HKDF-SHA-256 avec une étiquette propre à chaque usage (section 5.2) ; aucune clé ne sert à deux usages.	Vecteurs de test de la RFC 5869 ; clés dérivées distinctes deux à deux ; deux examens donnent deux clés d'empreinte.	1	1	AC-11, OS-10

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-CRY-05	Tous les aléas proviennent de `SecureRandom`. Sont interdits : `java.util.Random`, MD5, SHA-1 (hors TOTP), DES, RC4, AES-ECB, AES-CBC sans authentification, et tout algorithme cryptographique écrit par l'équipe.	Règle d'analyse statique bloquante : 0 occurrence.	1	1	DS-06
ES-CRY-06	La rotation de la KEK ré-enveloppe 100 % des clés de données sans rechiffrer les fichiers, en 10 minutes au plus pour 1 000 fichiers ; elle a lieu chaque année et sur suspicion de compromission.	Après rotation, 1 000 fichiers restent lisibles et l'ancienne KEK ne déchiffre plus rien ; durée mesurée.	2	5	AC-11, M-17
Intégrité et authenticité (ES-INT) – ASVS V11, V3 – cours : chapitre 3					
ES-INT-01	Le condensé SHA-256 de chaque sujet est calculé à l'import et recalculé avant toute génération ; en cas de divergence, la génération est bloquée et une alerte émise.	Un octet du fichier stocké modifié, puis génération demandée → refus, alerte, aucun exemplaire.	1	1	AC-05, OS-2
ES-INT-02	Le manifeste signé par SK_{man} authentifie ses champs (dont le hash de l'original). *En complément*, chaque exemplaire final, une fois intégralement sérialisé, fait l'objet d'un enregistrement détaché signé par SK_{file} comprenant identifiants, version, horodatage et SHA-256 du PDF exact, conservé hors fichier pour éviter toute boucle d'auto-signature.	Altérer un champ du manifeste : vérification refusée ; modifier un seul octet du PDF final : sa comparaison au digest détaché échoue même si le sceau reste valide ; signature externe vérifiée indépendamment.	1	1	AC-05, AC-09, M-09
ES-INT-03	Une distribution validée est immuable ; une correction passe par une révocation suivie d'une nouvelle distribution, toutes deux journalisées.	PUT et PATCH sur une distribution validée → 405 ; UPDATE direct → rejet par un déclencheur de la base.	1	2	AC-05, AC-09, M-09
ES-INT-04	Chaque page porte `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none'`. Aucune donnée d'utilisateur n'est insérée dans la page sans échappement (`dangerouslySetInnerHTML` interdit par ESLint).	Intitulé contenant une balise de script : affiché littéralement, non exécuté ; OWASP ZAP sans alerte sur la politique de contenu.	1	2	AC-02, AC-04, M-02
Non-répudiation (ES-NRP) – ASVS V16 – cours : chapitres 3 et 5					
ES-NRP-01	Toute opération sensible (ES-JRN-01) est liée à l'identité authentifiée, horodatée en UTC à la milliseconde (horloge NTP, dérive inférieure à 1 s) et journalisée avant d'être confirmée ; si l'écriture échoue, l'opération est annulée.	Journal rendu indisponible : une demande de distribution reçoit 503 et rien n'est créé.	1	3	AC-05, M-10, OS-7
ES-NRP-02	Chaque téléchargement produit un reçu signé par SK_{recu} (Ed25519) avec le hash de l'exemplaire servi, identifiant de distribution, identité du compte authentifié et horodatage UTC. Cette preuve démontre l'enregistrement par le serveur d'une délivrance au compte ; elle ne prouve ni la lecture effective ni la responsabilité humaine d'une fuite.	Vérification Ed25519 du reçu valide, rejet après altération d'un champ ; documentation du périmètre probant dans le rapport et absence de conclusion juridique automatique.	1	3	AC-05, AC-09, M-10, M-15
Validation des entrées et des fichiers (ES-VAL) – ASVS V1, V2, V5 – cours : chapitres 3 et 4					

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-VAL-01	Tous les champs reçus par l'API sont validés côté serveur par liste d'autorisation (type, longueur, motif) avec Jakarta Validation ; un champ inconnu ou invalide entraîne 400 ; un corps JSON ne dépasse pas 64 Kio.	Champ supplémentaire, trop long, de type erroné → 400 ; corps de 65 Kio → 413.	1	2	AC-04, M-08
ES-VAL-02	L'accès à la base se fait uniquement par requêtes à paramètres nommés ; toute concaténation de chaînes dans une requête est interdite.	Règle d'analyse statique bloquante ; balayage actif OWASP ZAP : 0 injection SQL.	1	2	AC-04, M-08
ES-VAL-03	Un sujet est un PDF : signature `%PDF-`, analyse complète par PDFBox en 30 s au plus, 20 Mio et 50 pages au plus, non chiffré, sans JavaScript, action automatique, fichier embarqué ni formulaire XFA. Il est stocké sous un nom égal à un UUID ; le nom fourni par le client n'est jamais un chemin.	Corpus de 10 fichiers piégés (un par motif) → 10 rejets (422) ; fichier de 21 Mio → 413 ; fichier nommé `../../etc/passwd` : rien n'est écrit hors du stockage.	1	1	AC-04, AC-12, M-07, M-18
ES-VAL-04	Avant marquage, le serveur compte les positions inter-mots réellement modifiables à travers *toutes les pages*, selon l'algorithme de l'annexe A.1. Si $N < 192$ positions, ou si l'écriture modifie texte/pagination/limites des lignes, l'exemplaire n'est pas produit ; aucune inférence n'est faite à partir du seul nombre de mots.	PDF de 4 pages avec 48 porteurs par page (192 au total) : les 64 bits sont décodés avec 3 répétitions ; 4 pages avec 40 porteurs : refus ; contenu texte extrait identique avant/après.	1	1	AC-07, CN-1
ES-VAL-05	L'import et l'investigation traitent tout PDF comme hostile. Une tâche séparée, sans accès réseau ni privilège et sous quotas de mémoire/processus/temps, contrôle les types, les tailles, les pages et les dimensions avant décodage quand cela est possible. Les fichiers d'investigation (PDF au plus 20 Mio ; PNG/JPEG au plus 10 Mio et 40 mégapixels) sont purgés après traitement.	PDF malformé, image 50 MP, zip/flux de compression agressif et PDF avec structure récursive : le worker est interrompu en cas de quota ; WildFly reste disponible ; fichiers temporaires nettoyés en moins de 60 s.	1	3	AC-04, AC-12, M-07
Dissimulation de l'information (ES-DIS) – chapitre 5 – cours : chapitres 3 et 6					
ES-DIS-01	Le mot de code HMAC (48 bits) et CRC-16 (16 bits) est étalé sur au moins 192 porteurs globaux du PDF, d'indice j mod 64 continu entre les pages. Chaque déplacement est $\leq 0{,}40$ pt ; chaque ligne conserve ses deux points de référence et la longueur des lignes ne varie pas au-delà de 0,01 pt sur le corpus admissible. Les copies sont différenciées, sans revendiquer une résistance automatique à la collusion.	PDF à 4 pages de 48 porteurs : aucune position de code perdue après changement de page ; texte, sélection et pagination identiques ; 1 000 distributions donnent 1 000 identifiants HMAC distincts sur l'échantillon.	1	1	AC-07, CN-1

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-DIS-02	Sur des exemplaires complets non modifiés du corpus admissible, l'empreinte est récupérée dans 100% des cas. Un objectif de 95% est fixé pour la simple resérialisation PDF sans recomposition du texte. Une page extraite n'est identifiable individuellement que si elle porte au moins 192 positions exploitables ; sinon la conclusion est « preuve insuffisante ».	Banc sur 50 exemplaires : 50/50 exacts ; objectif 48/50 sur la transformation T1. Extraction isolée de page sous-capacitaire : aucune désignation.	1	4	AC-07, M-12
ES-DIS-03	Le CRC-16 ne fournit qu'un contrôle d'erreur ; chaque identifiant décodé est vérifié par recomputation HMAC de la distribution candidate. Aucun verdict *Exact* ou *Concordant* n'est émis sur un CRC valide seul, en présence de marques contradictoires, d'une ambiguïté de candidats ou d'un indice de collusion. L'outil ne garantit pas l'impossibilité universelle de fausse attribution.	1 000 PDF non marqués, 100 mélanges d'exemplaires et 100 échanges de sceaux A/B : zéro *verdict Concordant* erroné dans ce corpus ; toute divergence entraîne abstention et conservation des indicateurs d'incertitude.	1	4	AC-08, AC-09, M-14, M-15
ES-DIS-04	*Watermarking*, imperceptibilité : PSNR d'au moins 42 dB et SSIM d'au moins 0,98 entre bandeau d'origine et bandeau marqué.	Banc : seuils tenus pour 20 bandeaux sur 20.	1	1	AC-07, CN-1
ES-DIS-05	La récupération du filigrane DWT–DCT–QIM est *une cible expérimentale* : pour chaque transformation du banc (JPEG Q70, échelles 50% et 200%, bruit gaussien $\sigma = 3$, conversion de format), au moins 95% des 20 bandeaux marqués sont correctement identifiés. Aucune résistance à la suppression délibérée du bandeau n'est promise.	Courbes BER/PSNR/SSIM et réussite par transformation ; au moins 19/20 sous chaque réglage ; 1 000 bandeaux non marqués : 0 fausse identification sur l'échantillon déclaré.	1	4	AC-07, M-12, M-13
ES-DIS-06	Le manifeste est inséré par LSB matching sur moins de 2% des composantes du sceau, avec PSNR cible de 60 dB. La discrétion statistique est évaluée, sans garantie d'indétectabilité : comparaison d'un détecteur statistique (AUC ROC) sur un jeu de 200 sceaux marqués et 200 vierges, indépendant du réglage des paramètres.	Mesurer PSNR et AUC sur données de test inédites ; documenter l'AUC, le faux positif, les intervalles de confiance et toute faiblesse observée. Une AUC élevée constitue un échec à analyser, jamais un succès masqué.	2	4	AC-10, M-16
ES-DIS-07	Chaque manifeste signé (Ed25519) est chiffré en AES-256-GCM avant son insertion. Le nonce 96 bits est tiré aléatoirement et ne doit jamais être réutilisé sous la même clé ; le parcours de placement ChaCha20 dispose d'une clé distincte, dédiée à cet usage. Un manifeste validé atteste uniquement les champs signés, non l'intégrité du PDF complet.	100 exemplaires numériques intacts : 100 signatures et tags valides ; 100 mutations de charge : 100 refus ; 10 000 nonces GCM distincts sous la clé testée ; modification d'une page hors sceau : manifeste possiblement valide mais aucune affirmation d'intégrité globale.	1	1	AC-07, AC-10, M-16

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-DIS-08	La cryptographie ne repose pas sur le secret des algorithmes : chaque domaine de clés (HMAC des identifiants, permutation du filigrane, position du sceau, chiffrement GCM, signature) dispose d'une dérivation HKDF distincte et versionnée ; aucune marque ne contient de nom ou d'e-mail en clair. La copie/transplantation d'une marque reste une menace prise en compte.	Revue des étiquettes HKDF et tests vecteurs ; toutes clés dérivées de domaines distincts sont différentes ; extraction des trois marqueurs : aucun identifiant directement personnel.	1	1	AC-09, OS-9, OS-10
ES-DIS-09	Le rapport distingue les niveaux Exact / Concordant / Indice isolé / Examen seul / Indéterminé selon le tableau 5.2. Il ne désigne fermement une copie que sur SHA-256 final et preuve détachée Ed25519 valides, ou indique une distribution probable lorsque manifeste et fingerprint concordent. Aucune personne humaine n'est déclarée responsable et les conflits imposent abstention.	12 combinaisons, dont copie exacte, sceau transplanté, contenu modifié hors sceau, empreinte mélangée et métadonnées supprimées : règles identiques au tableau, avertissement de portée présent dans 100% des rapports.	1	3	AC-08, AC-09, M-15, CN-5
ES-DIS-10	L'investigation est réservée à l'auditeur, limitée à 20 analyses par heure, et chaque analyse est journalisée avec le condensé du fichier soumis.	21e analyse dans l'heure $\rightarrow$ 429 ; une entrée de journal par analyse.	2	3	AC-10, M-16
Journalisation, audit et détection d'intrusion (ES-JRN) – ASVS V16 – cours : chapitre 5					
ES-JRN-01	Sont journalisés : authentifications réussies et échouées, verrouillages, gestion des comptes et des rôles, imports, générations, distributions, révocations, téléchargements, investigations, refus d'autorisation, rejets de fichiers. Chaque entrée comporte 8 champs : horodatage, utilisateur, rôle, adresse IP, action, objet, résultat, identifiant de corrélation.	Un test par type d'événement : entrée présente, 8 champs renseignés.	1	3	AC-06, OS-7
ES-JRN-02	Un journal ne contient jamais de mot de passe, de code TOTP, d'identifiant de session, de clé ni de contenu de sujet. Les données d'origine utilisateur y sont encodées : un retour à la ligne ne crée pas de fausse entrée.	Parcours avec valeurs sentinelles : 0 occurrence dans les journaux ; identifiant contenant un retour à la ligne $\rightarrow$ une seule entrée.	1	3	AC-04, AC-06
ES-JRN-03	Les entrées d'audit séquencées sont liées par $h_i = \text{SHA-256}(h_{i-1} \| i \| e_i)$ sur une sérialisation canonique. Une ancre journalière (premier et dernier numéros, compte, racine) est signée par SK_{ancre} (Ed25519) et transférée sur un support append-only *hors des droits de PostgreSQL*. Vérification au redémarrage et au plus tard toutes les 24 h ; un superutilisateur de la base ne peut recalculer l'ancre signée.	Sur 1 000 événements ancrés : modification, suppression, insertion et réordonnancement en base par superutilisateur : quatre anomalies détectées, avec identifiant de séquence et alerte. Refus d'écriture si ancrage indisponible selon règle d'exploitation.	1	3	AC-06, M-11

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-JRN-04	Une alerte est affichée à l'administrateur et à l'auditeur en 60 secondes au plus. R1 : 5 échecs d'authentification sur un compte en 15 minutes. R2 : 10 refus d'autorisation pour un utilisateur en 10 minutes. R3 : téléchargement hors fenêtre ou hors quota. R4 : rupture de la chaîne d'audit. R5 : 3 fichiers rejetés pour un utilisateur en 1 heure.	Un test par règle : le scénario déclencheur produit l'alerte en 60 secondes au plus ; juste sous le seuil, aucune alerte.	1	3	AC-01, AC-03, AC-06
Gestion des erreurs (ES-ERR) – ASVS V16 – cours : chapitre 5					
ES-ERR-01	Les erreurs de l'API suivent le format unique de la RFC 9457 ; aucune réponse ne contient de trace d'exécution, de requête SQL, de chemin ni de version ; les en-têtes `Server` et `X-Powered-By` sont supprimés.	10 erreurs provoquées : 0 occurrence des motifs `Exception`, `at org.`, `SQL`, `WildFly`.	2	3	AC-04, M-08
ES-ERR-02	Échec sûr : une exception dans un contrôle d'authentification ou d'autorisation entraîne un refus, jamais un accès.	Faute injectée dans le service d'autorisation → aucune réponse 200 sur les requêtes protégées.	1	3	AC-03, M-05
Résilience et disponibilité (ES-DSP) – ASVS V2, V13 – cours : chapitres 3 et 7					
ES-DSP-01	Le débit est limité à 100 requêtes par minute et par session et à 300 par adresse IP ; au-delà, 429 avec `Retry-After`.	101e requête d'une session dans la minute → 429.	1	5	AC-12, M-18
ES-DSP-02	Les traitements sont bornés : génération d'un exemplaire en 10 s au plus (sujet de 10 pages), investigation en 30 s au plus, interruption au-delà ; 8 traitements de marquage simultanés au plus ; 4 calculs Argon2id simultanés au plus (256 Mio), file de 20 places puis 429.	Traitement prolongé artificiellement → interrompu ; 50 connexions simultanées : mémoire de hachage $\leq$ 256 Mio, excédent → 429.	1	4	AC-12, M-18, CN-4
ES-DSP-03	Sous 20 utilisateurs simultanés pendant 5 minutes, le 95e centile du temps de réponse de l'API, hors fichiers, ne dépasse pas 500 ms et le taux d'erreurs 5xx reste sous 1 %. La disponibilité mesurée par sonde sur `/api/health` pendant les fenêtres de distribution est d'au moins 99,5 %.	Test de charge de 5 minutes : seuils tenus ; rapport de la sonde sur la période de démonstration.	2	4	AC-12, OS-8
ES-DSP-04	La base, le stockage et le *credential store* sont sauvegardés chaque jour, chiffrés par AES-256-GCM, le *credential store* sur un support distinct. Perte de données maximale : 24 heures ; délai de rétablissement : 4 heures.	Exercice de restauration sur un hôte vierge avant la soutenance : service rétabli en moins de 4 heures, chaîne d'audit vérifiée ; sauvegarde illisible sans clé.	2	5	AC-11, M-17, OS-8
Protection des données personnelles (ES-PRV) – ASVS V14 – directive DS-04 – cours : chapitre 4					
ES-PRV-01	Les seules données personnelles collectées sont le nom, le prénom, l'adresse institutionnelle et le rôle. La correspondance entre une empreinte et un destinataire n'est accessible qu'à l'investigation, pour l'auditeur.	Revue du schéma de la base ; aucune réponse aux rôles enseignant, responsable et administrateur ne contient d'identifiant d'empreinte.	2	2	DS-04, OS-9

ID	Exigence	Critère de vérification (test)	P	It.	Origine
ES-PRV-02	Exemplaires et associations de distribution sont conservés 12 mois après l'épreuve, puis purgés par traitement journalisé. Les journaux sont conservés 12 mois sous segments chaînés et ancrés ; leur purge s'effectue par segments complets, avec preuve de fermeture signée. Un compte fermé est désactivé, puis la correspondance nominative est supprimée ou pseudonymisée sous 30 jours sans réécrire rétroactivement le journal signé.	Purge par segment sur dataset antidaté ; intégrité de la chaîne restante vérifiable ; identité nominative non retrouvée via l'API après 30 jours, sans suppression arbitraire de traces chaînées individuelles.	2	5	DS-04, OS-9
ES-PRV-03	À sa première connexion, l'utilisateur est informé que les exemplaires sont individualisés et les téléchargements tracés ; sa prise de connaissance est journalisée. Chaque page d'un exemplaire porte la mention visible prévue par F-10.	L'écran d'information précède tout autre écran ; mention présente sur 100 % des pages.	2	2	AC-07, M-13, DS-04
Configuration, déploiement et chaîne logicielle (ES-CFG) – ASVS V13, V15 – cours : chapitres 6 et 7					
ES-CFG-01	Le *service worker* ne met en cache que l'enveloppe statique ; aucune réponse sous `/api/` n'est conservée dans le cache ni dans IndexedDB ; les réponses de l'API et les téléchargements portent `Cache-Control: no-store`.	Playwright : après téléchargement, aucune entrée `/api/` en cache ; hors connexion, aucun sujet affichable.	1	2	AC-03, M-06, CN-2
ES-CFG-02	L'interface de gestion de WildFly n'écoute que sur 127.0.0.1 ; les applications par défaut sont retirées ; WildFly s'exécute sous le compte non privilégié `wildfly` ; seul le port 443 est exposé ; le mode de débogage est désactivé en production.	Balayage de ports externe : 443 seul ; page d'accueil par défaut → 404 ; processus non `root`.	1	5	OS-6
ES-CFG-03	Les dépendances sont analysées à chaque construction (OWASP Dependency-Check, `npm audit`) ; une vulnérabilité de score CVSS d'au moins 7,0 fait échouer la construction, sauf dérogation documentée.	Dépendance vulnérable introduite volontairement → échec de la construction.	2	4	AC-04, M-07
ES-CFG-04	La branche principale est protégée ; toute demande de fusion touchant l'authentification, la cryptographie ou le marquage est relue par un autre membre ; avant chaque jalon, un balayage OWASP ZAP passif puis actif ne laisse aucune alerte de niveau élevé.	Paramètres de protection de branche ; 100 % des fusions étiquetées `security` ont un relecteur distinct ; rapport ZAP archivé.	2	1	DS-03, DS-05

9. Validation et traçabilité

9.1 Stratégie de test

La validation repose sur trois niveaux de tests, complétés par l'inspection croisée des exigences. **TS** : le critère de vérification de chaque exigence ES est son test ; la couverture des 57 exigences est donc complète par construction. **TA** : chaque cas d'abus est rejoué contre le système déployé ; le test réussit si l'attaque échoue et laisse une trace (12 tests). **TF** : tests fonctionnels du scénario métier (12 tests). Les tests automatisables s'exécutent en intégration continue ; les tests d'abus et le banc de marquage sont exécutés à chaque jalon à partir de l'itération 4. Le détail des tests TA et TF figure dans l'annexe C.

Une exigence est validée lorsque son test a été exécuté, que le résultat observé est le résultat attendu et que le rapport est archivé. Une itération est acceptée lorsque toutes ses exigences P1 sont validées.

9.2 Du cas d'abus au test

Cas d'abus	Menaces	Parade	Exigences	Test
AC-01 Force brute, bourrage d'identifiants	M-01	SUC-01	ES-AUT-01 à 05, ES-DSP-02	TA-01
AC-02 Détournement de session	M-02, M-03	SUC-02	ES-SES-01 à 03, ES-CRY-01, ES-INT-04	TA-02
AC-03 Accès non autorisé à une ressource	M-04 à M-06	SUC-03, SUC-10	ES-AUZ-01 à 04, ES-ERR-02, ES-CFG-01, ES-SES-02	TA-03
AC-04 Données ou fichiers malveillants	M-07, M-08	SUC-04	ES-VAL-01 à 03, ES-VAL-05, ES-INT-04, ES-ERR-01, ES-JRN-02, ES-AUZ-05, ES-CFG-03	TA-04
AC-05 Falsification ou répudiation d'une distribution	M-09, M-10	SUC-05	ES-INT-01 à 03, ES-NRP-01, ES-NRP-02	TA-05
AC-06 Altération du journal d'audit	M-11	SUC-06	ES-JRN-01 à 04, ES-AUZ-05	TA-06
AC-07 Effacement des marques	M-12, M-13	SUC-07	ES-DIS-01, 02, 04, 05, 07, ES-VAL-04, ES-PRV-03 ; risque résiduel	TA-07
AC-08 Collusion de destinataires	M-14	SUC-07, SUC-08	ES-DIS-03, ES-DIS-09	TA-08
AC-09 Incrimination d'un innocent	M-15	SUC-08	ES-DIS-03, 08, 09, ES-INT-02, ES-INT-03, ES-AUZ-02, ES-NRP-02	TA-09
AC-10 Stéganalyse, oracle d'investigation	M-16	SUC-08, SUC-09	ES-DIS-06, 07, 10	TA-10
AC-11 Vol des clés	M-17	SUC-09	ES-CRY-02 à 04, ES-CRY-06, ES-DSP-04	TA-11
AC-12 Déni de service applicatif	M-18	SUC-11	ES-DSP-01 à 03, ES-AUT-05, ES-VAL-03, ES-VAL-05	TA-12

La colonne « Origine » du chapitre 8 donne le lien inverse. Les exigences qui ne découlent pas d'un cas d'abus mais d'une directive ou d'un objectif sont ES-CRY-05 (DS-06), ES-PRV-01 et ES-PRV-02 (DS-04), ES-CFG-02 (OS-6) et ES-CFG-04 (DS-03, DS-05).

10. Gestion des exigences

10.1 Processus de changement et suivi

Le recueil évolue avec l'agenda du cours. Toute évolution suit cinq étapes : **demande** par une *issue* GitHub étiquetée `exigence`, avec son motif ; **analyse d'impact** sur les cas d'abus, menaces, exigences et tests, à l'aide de la matrice de traçabilité ; **décision** du trinôme, et de l'encadrant pour une décision technique ou une exigence P1 ; **mise à jour** des sources LaTeX sous `docs/src/` et du PDF sous `docs/`, un identifiant retiré n'étant jamais réattribué ; **vérification** par inspection croisée et exécution des tests.

Chaque exigence et chaque couple de récits sont suivis par une *issue* portant sa priorité et son itération. Une demande de fusion cite les exigences qu'elle réalise et n'est fusionnée que si leurs tests réussissent. Définition de « terminé » : code relu, tests au vert, aucune alerte bloquante de l'analyse statique, des dépendances et de la détection de secrets.

10.2 Planification par itération

Les mécanismes d'authentification et d'autorisation (DT-09) seront réexaminés à l'issue du chapitre 4 du cours.

It.	Chapitre du cours	Contenu	Exigences de sécurité	Nb
1	3 – Confidentialité, intégrité, disponibilité	Import du sujet, chiffrement, clés, insertion des trois marques. F-04 à F-06, F-08, F-10, F-11, F-13.	ES-CRY-01 à 05 ; ES-INT-01, 02 ; ES-VAL-03, 04 ; ES-DIS-01, 04, 07, 08 ; ES-CFG-04	14
2	4 – Authentification, autorisation, informations privées	Comptes, sessions, contrôle d'accès, distribution, téléchargement, PWA. F-01 à F-03, F-07, F-12, F-14, F-15, F-21.	ES-AUT-01 à 05 ; ES-SES-01 à 03 ; ES-AUZ-01 à 04 ; ES-INT-03, 04 ; ES-VAL-01, 02 ; ES-PRV-01, 03 ; ES-CFG-01	19
3	5 – Journalisation et gestion des erreurs	Journal chaîné, alertes, erreurs, investigation et rapport. F-09, F-16 à F-20.	ES-AUZ-05 ; ES-NRP-01, 02 ; ES-VAL-05 ; ES-DIS-09, 10 ; ES-JRN-01 à 04 ; ES-ERR-01, 02	12
4	6 – Tests de sécurité	Banc d'évaluation du marquage, tests d'abus, analyse dynamique, charge.	ES-DIS-02, 03, 05, 06 ; ES-DSP-02, 03 ; ES-CFG-03	7
5	7 – Déploiement et maintenance	Durcissement, sauvegarde et restauration, rotation des clés, purge.	ES-CRY-06 ; ES-DSP-01, 04 ; ES-PRV-02 ; ES-CFG-02	5

10.3 Évolution depuis la version 1.0

Version 1.0	Version 2.0
S-01 à S-07 (authentification, sessions, autorisation), sans paramètre	ES-AUT-01 à 05, ES-SES-01 à 03, ES-AUZ-01 à 05 : algorithme, durées et seuils fixés.
S-08 à S-15 (fichiers, confidentialité), sans limite ni algorithme	ES-VAL-03 à 05, ES-CRY-01 à 06, ES-INT-01, ES-DIS-07, ES-CFG-01.
S-16 à S-19 (vulnérabilités applicatives)	ES-VAL-01, ES-VAL-02, ES-ERR-01, ES-CRY-03.
S-20 à S-23 (journalisation), limitée aux utilisateurs ordinaires	ES-JRN-01 à 04, ES-NRP-01 : journal chaîné, détection des altérations par un acteur privilégié.
S-24, S-25 (ressources, disponibilité), non mesurables	ES-DSP-01 à 04.
S-26 et § 4.8 (mises en garde)	ES-DIS-09, ES-NRP-01, ES-NRP-02 : exigences testables.
Chapitre 6 (SLI, SLO, RPO, RTO)	Supprimé ; valeurs reprises par ES-DSP-03 et ES-DSP-04.
Chapitre 10 (points à préciser)	Décisions DT-01 à DT-15.

La table de correspondance exigence par exigence figure dans l'annexe E.

11. Limites et risques résiduels

Les risques suivants ne sont pas couverts, ou ne le sont que partiellement. Ils sont déclarés pour que le niveau de protection réel soit connu.

Risque	**Limite**	**Traitement**
Fuite par voie analogique (M-13)	Une photographie ou une numérisation détruit le manifeste et dégrade l'empreinte ; seul le filigrane peut subsister : l'examen est identifié, pas le destinataire.	Accepté ; dissuasion (ES-PRV-03). Résistance de l'empreinte à la numérisation : objectif étendu.
Recomposition du texte (M-12)	Qui recompose le texte et retire le bandeau et le sceau efface les trois marques.	Accepté ; le journal des téléchargements borne la liste des suspects.
Collusion (M-14)	Le système détecte l'incohérence et s'abstient, mais n'identifie pas les colludeurs.	Abstention (ES-DIS-03). Code anti-collusion : objectif étendu.
Valeur probante (M-15)	Une marque rattache un fichier à une distribution, non à une personne.	Rapport gradué (ES-DIS-09), reçus (ES-NRP-02).
Acteurs privilégiés (M-11)	Un administrateur de la base peut altérer le journal ; un administrateur du système peut lire les clés.	Altération détectée, non empêchée. Dépôt de l'ancre hors de l'hôte : objectif étendu.
Sujets pauvres en texte	Un sujet fait surtout de formules ou de figures n'offre pas 192 porteurs.	Refus explicite (ES-VAL-04) ; filigrane et manifeste restent applicables.

Les objectifs étendus ne sont pas des exigences : ils ne seront entrepris que si toutes les exigences P1 et P2 sont validées.

Conclusion

Cette version remplace une liste d'intentions par des engagements vérifiables : une démarche d'ingénierie des exigences de sécurité choisie et justifiée à partir des critères du cours ; douze cas d'abus, dont quatre propres à la dissimulation de l'information, contrecarrés par onze cas d'utilisation de sécurité ; dix-huit menaces cotées ; des choix techniques figés ; cinquante-sept exigences portant chacune un mécanisme, un seuil, un test, une priorité et une itération. Le document sera révisé à l'issue de chaque chapitre du cours, et les seuils de la famille ES-DIS seront confrontés aux mesures du banc d'évaluation dès l'itération 4.